



Módulo 1:

## **Diseño de redes seguras**

Unidad 2:

## **Instalación y configuración en redes**



## Presentación

En esta segunda Unidad del curso, nos introducimos en la comprensión de la temática correspondiente a lo que hay que tener en cuenta antes de empezar el armado de una red.

Se explicará la importancia de un direccionamiento IP adecuado, para poder identificar correctamente los dispositivos.

Se verán distintos dispositivos de seguridad, donde los mismos cobran importancia mayor en cuanto a la distribución de donde ubicarlos.



## Objetivos

Que los participantes logren...

- Conocer los conceptos generales de las redes de comunicación, los protocolos, los diferentes dispositivos y sus funciones.
- Aprender a planear, diseñar, estructurar e implementar una infraestructura de red informática de manera segura, protegiéndola de potenciales amenazas.



## Bloques temáticos

1. Modelo TCP/IP.
2. Direccionamiento IP.
3. Seguridad en redes.

## Modelo TCP/IP



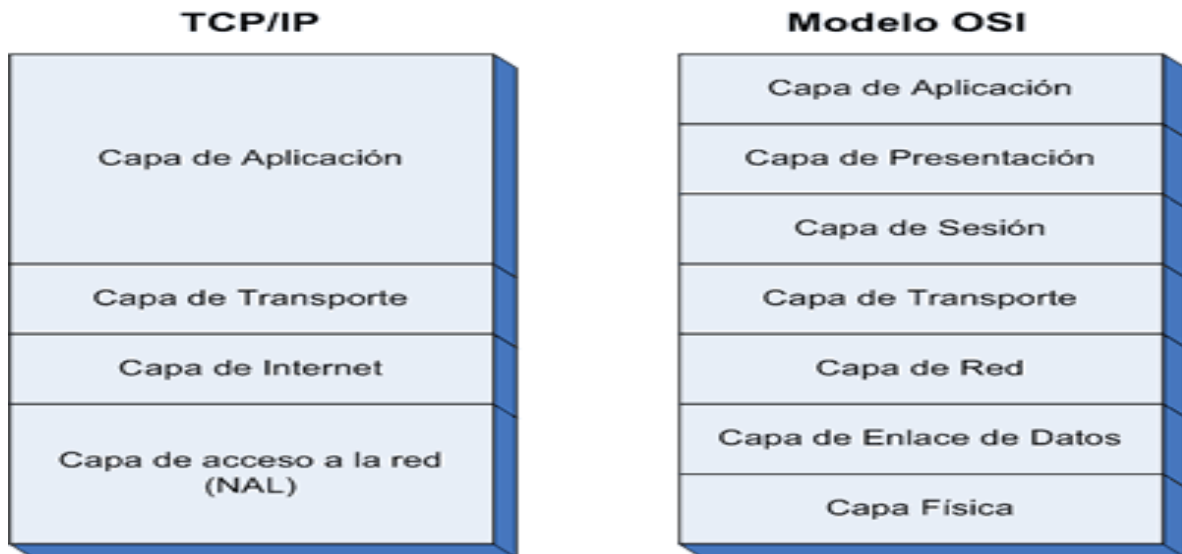
Conocido como una “suite de protocolos”, ya que está formado por dos protocolos: **TCP** (Transmission Control Protocol) e **IP** (Internet Protocol).

Provee todos los servicios necesarios para poder conectar distintos dispositivos en redes formadas por distintos tipos de dispositivos.

Un dispositivo puede tener una configuración diferente a lo habitual, pero mientras siempre y cuando se use **TCP/IP**, se podrá comunicar con los demás dispositivos.

Todos los equipos permiten el uso de **TCP/IP** para sus comunicaciones, siendo esta la configuración utilizada por los administradores de red.

A diferencia del **MODELO OSI**, **TCP/IP** tiene 4 capas.



### Aplicación, Transporte, Internet y Acceso a la red

En la capa de Aplicación, se engloban las mismas actividades que se realizan en el Modelo **OSI** (Aplicación, Presentación y Sesión).



Esta capa administra todas las funciones utilizadas y requeridas por las aplicaciones y los servicios que tengan una relación directa con el usuario final: **HTTP, SMTP, FTP, ETC.**

La capa de Transporte, corresponde a la misma que el Modelo **OSI**.



Se encarga de proveer la conectividad de punta a punta entre el origen (emisor) y el destinatario (receptor) y permite intercambiar los roles de emisor y receptor dinámicamente.

La capa de Internet, corresponde a la capa de red del Modelo **OSI**.



Se encarga de definir el esquema de direccionamiento lógico de los equipos que se conecten a la red y el direccionamiento de c/u de los equipos de la red.

Contamos también con un servicio de enrutamiento, para todos los equipos que estén conectados a la red, donde contará con toda la información relacionada a los equipos de origen y destino en la comunicación.

Por último, tenemos la capa de Acceso a la red correspondiendo a las capas de enlace de datos y física del modelo **OSI**.



Aquí se define el acceso de modo de acceso físico a la red, y la traducción del direccionamiento físico al lógico.

Por eso encontraremos que trabaja con el protocolo ARP, lo mismo que en la capa de enlace de datos del modelo **OSI**.

Acá operan todos los protocolos encargados de preparar el ambiente físico y lógico necesario para realizar las comunicaciones.

# Protocolo IP

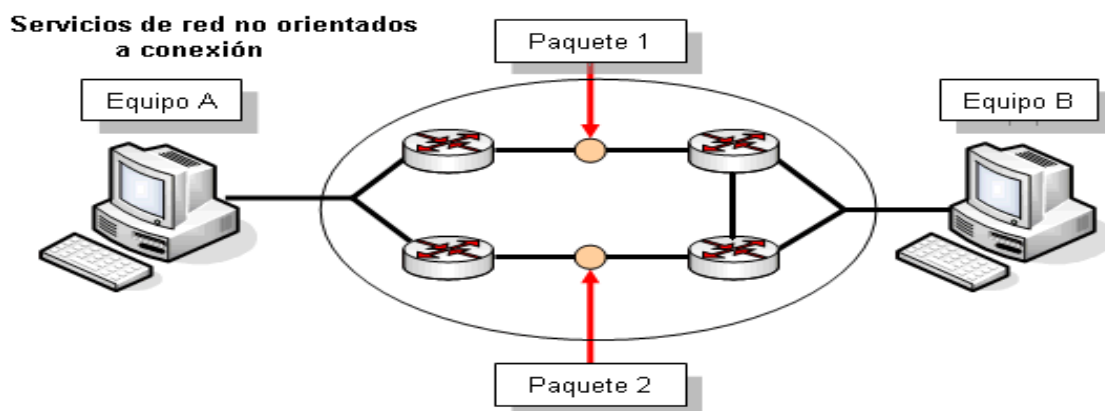


Es un protocolo de comunicación de datos en la Capa de Red según el modelo internacional **OSI**.

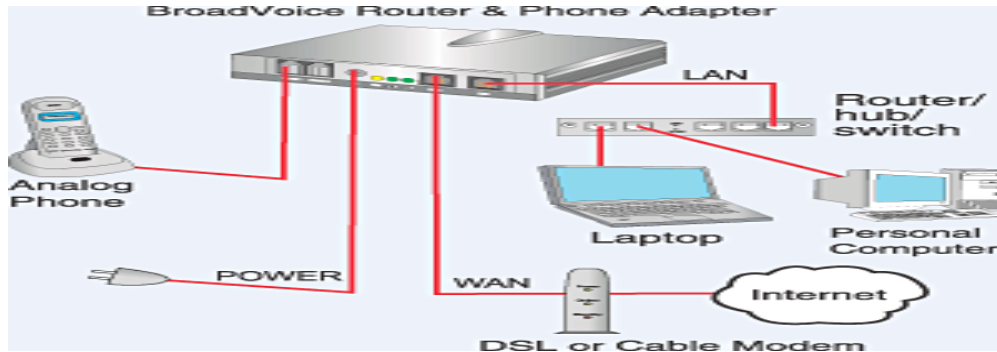
Su función es el uso bidireccional en origen o destino de comunicación para transmitir datos mediante un protocolo **no orientado a conexión** que transfiere paquetes conmutados a través de distintas redes físicas previamente enlazadas según la norma **OSI** de enlace de datos.

No orientado a la conexión significa una comunicación entre dos puntos finales de una red en los que un mensaje puede ser enviado desde un punto final a otro sin acuerdo previo.

Los paquetes pueden tomar distintas rutas para atravesar la red, pero se vuelven a ensamblar cuando llegan a su destino y en un sistema no orientado a conexión, no se hace contacto con el destino antes de que se envíe el paquete.



Las cabeceras IP contienen las direcciones de las máquinas de origen y destino (direcciones IP), direcciones que serán usadas por los enrutadores (routers) para decidir el tramo de red por el que enviarán los paquetes.



IP provee un servicio de datagramas no fiable (también llamado del "**mejor esfuerzo**"), lo hará lo mejor posible pero garantizando poco).

IP no provee ningún mecanismo para determinar si un paquete alcanza o no su destino y únicamente proporciona seguridad (mediante *checksums* o sumas de comprobación) de sus cabeceras y no de los datos transmitidos.

Si se necesita fiabilidad, ésta es proporcionada por los protocolos de la **capa de transporte** como **TCP**.

## TIPS: Direccionamiento vs Enrutamiento

Cuando hablamos de **direccionamiento**, nos estamos refiriendo a una “etiqueta” que nos encontramos en el dispositivo o elemento de la red.

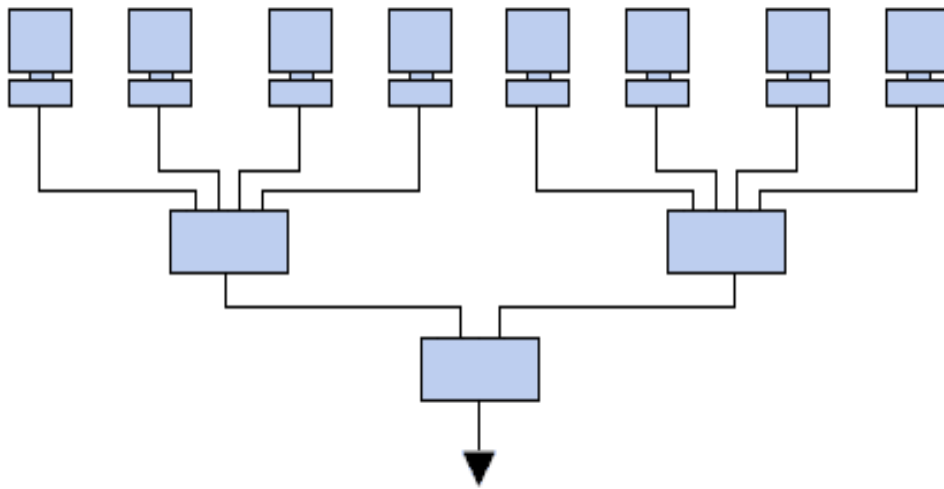
Dentro de una red, necesitamos “identificar” a todos los dispositivos para la comunicación entre ellos o con agentes externos.

**Enrutamiento**, significa “aprender” la manera de encontrar un equipo o una determinada “IP” dentro de esa red.

En la tabla de enrutamiento, se encuentran todas las redes publicadas y/o aprendidas, por intermedio de protocolos de enrutamiento (BGP, EIGRP, IGRP, RIP, rutas estáticas, etc.).

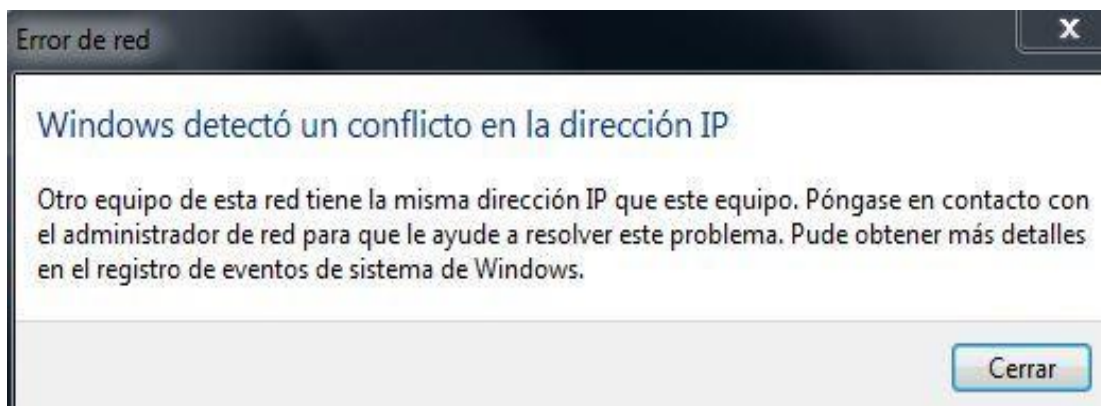
# Direccionamiento IP

Una dirección IP es un número que identifica de manera lógica y jerárquicamente a una interfaz de un dispositivo dentro de una red que utilice el protocolo de Internet.



Observando una red como el dibujo anterior, es imposible relacionar un equipo con otro para que puedan comunicarse entre sí, al menos una etiqueta que los identifique.

**Una dirección IP asignada a un equipo es única** (no pueden existir dos equipos en la misma red con la misma dirección).



El mismo sistema operativo, interpretará que no es posible la comunicación debido a esa reiteración de direccionamiento **IP**.

La máscara de red es una combinación de bits que sirve para delimitar el ámbito de una red de computadoras.

|     |               |     |                 |
|-----|---------------|-----|-----------------|
| /8  | 255.0.0.0     | /20 | 255.255.240.0   |
| /9  | 255.128.0.0   | /21 | 255.255.248.0   |
| /10 | 255.192.0.0   | /22 | 255.255.252.0   |
| /11 | 255.224.0.0   | /23 | 255.255.254.0   |
| /12 | 255.240.0.0   | /24 | 255.255.255.0   |
| /13 | 255.248.0.0   | /25 | 255.255.255.128 |
| /14 | 255.252.0.0   | /26 | 255.255.255.192 |
| /15 | 255.254.0.0   | /27 | 255.255.255.224 |
| /16 | 255.255.0.0   | /28 | 255.255.255.240 |
| /17 | 255.255.128.0 | /29 | 255.255.255.248 |
| /18 | 255.255.192.0 | /30 | 255.255.255.252 |
| /19 | 255.255.224.0 |     |                 |

El número que viene después de la “/” es la suma de los bits que se utilizan para la máscara de red, esa identificación se la conoce como **CIDR**.

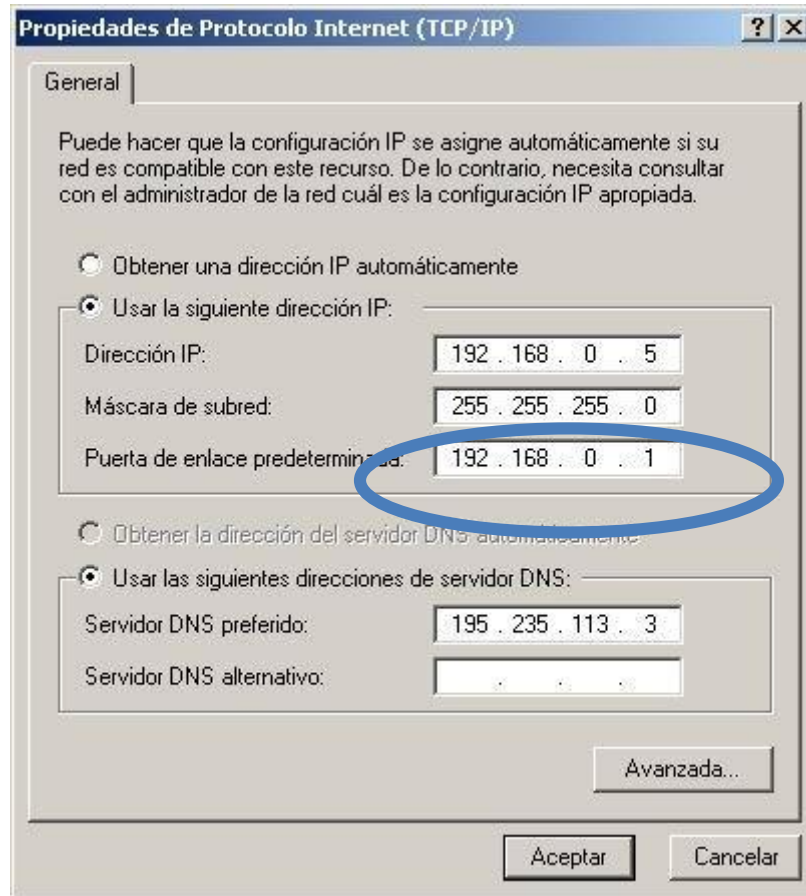
La función principal de la máscara de red es indicar a los dispositivos qué parte de la dirección IP es el número de la red, incluyendo la subred, y qué parte es la correspondiente al host.

Los primeros bits nos indicarán los distintos segmentos.



Una puerta de enlace o Gateway es un dispositivo que permite interconectar redes con protocolos y arquitecturas diferentes a todos los niveles de comunicación.

Su función es traducir la información del protocolo utilizado en una red al protocolo usado en la red de destino.



Atención con ese valor, dado que el mismo se puede configurar manualmente o por intermedio de un servidor de **DHCP**.

Esa **IP** que se encuentra como puerta de enlace o default Gateway, indicará al “tráfico de red” generado, por donde tiene que salir (generalmente es la IP de un router).

**En conclusión: DIRECCIÓN IP – MASCARA - GATEWAY**

**Ejemplo:**

**IP de Dispositivo: 192.168.0.128**

**Máscara de red: 255.255.255.0**

**Default Gateway/Puerta de enlace: 192.168.0.1**

```

C:\Users\aulaClic>ipconfig

Configuración IP de Windows

Adaptador LAN inalámbrico Conexión de red inalámbrica:

    Sufijo DNS específico para la conexión. . . : 
    Vínculo: dirección IPv6 local. . . : fe80::bca9:a89b:d7a7:be62%9
    Dirección IPv4 de configuración automática: 169.254.190.98
    Máscara de subred . . . . . : 255.255.0.0
    Puerta de enlace predeterminada . . . . . : 

Adaptador de Ethernet Conexión de área local:

    Sufijo DNS específico para la conexión. . . : lan
    Vínculo: dirección IPv6 local. . . : fe80::7c7a:7f7b:920:2a9a%8
    Dirección IPv4. . . . . : 192.168.0.128
    Máscara de subred . . . . . : 255.255.255.0
    Puerta de enlace predeterminada . . . . . : 192.168.0.1

```

### **QUE SON LAS DIRECCIONES IP FIJAS o ESTÁTICAS – IP DINAMICAS**

Cuando nos conectamos desde nuestra casa u oficina a **INTERNET** utilizamos una dirección IP

Esta dirección puede cambiar al reiniciar el dispositivo, lo que ese cambio de dirección de la IP se denomina “*IP dinámica*”

Los sitios de Internet que visitamos necesitan estar siempre conectados, generalmente tienen una “*IP fija*”; es decir, no cambia con el tiempo

Los servidores de correo, DNS, FTP públicos, servidores web, conviene que tengan una dirección IP fija o estática, ya que de esta forma se facilita su ubicación.

Hay tres clases de direcciones IP que una organización puede recibir de parte de la Internet Corporation for Assigned Names and Numbers (**ICANN**).

Clase A, Clase B y Clase C (la D y la E son reservadas).

| CLASE    | DIRECCIONES DISPONIBLES |                 | CANTIDAD DE REDES | CANTIDAD DE HOSTS | APLICACIÓN     |
|----------|-------------------------|-----------------|-------------------|-------------------|----------------|
|          | DESDE                   | HASTA           |                   |                   |                |
| <b>A</b> | 0.0.0.0                 | 127.255.255.255 | 128*              | 16.777.214        | Redes grandes  |
| <b>B</b> | 128.0.0.0               | 191.255.255.255 | 16.384            | 65.534            | Redes medianas |
| <b>C</b> | 192.0.0.0               | 223.255.255.255 | 2.097.152         | 254               | Redes pequeñas |
| <b>D</b> | 224.0.0.0               | 239.255.255.255 | no aplica         | no aplica         | Multicast      |
| <b>E</b> | 240.0.0.0               | 255.255.255.255 | no aplica         | no aplica         | Investigación  |

\* El intervalo 127.0.0.0 a 127.255.255.255 está reservado como dirección loopback y no se utiliza.

Estos rangos se separan lo que es direccionamiento privado y público, donde el privado es para la red LAN y el público para todo lo que sea WAN (esto incluye servidores o servicios que se expongan a Internet, aun siendo de una LAN).

#### **Direccionamiento RESERVADO Y PRIVADO:**

| Red o rango                 | Uso                        |
|-----------------------------|----------------------------|
| 127.0.0.0                   | Reservado (fin clase A)    |
| 128.0.0.0                   | Reservado (inicio Clase B) |
| 191.255.0.0                 | Reservado (fin clase B)    |
| 192.0.0.0                   | Reservado (inicio Clase C) |
| 224.0.0.0                   | Reservado (inicio Clase D) |
| 240.0.0.0 – 255.255.255.254 | Reservado (clase E)        |
| 10.0.0.0                    | Privado                    |
| 172.16.0.0 – 172.31.0.0     | Privado                    |
| 192.168.0.0 – 192.168.255.0 | Privado                    |

**Todo direccionamiento no expuesto, es considerado direccionamiento público**

## Ejercicio Número 1 Unidad 2



Crear un informe explicando que son las bases de datos “**WHOIS**” y cuáles son las correspondientes a nuestra zona (continente) y país.



ATENCIÓN: en Linux existe un comando llamado “WHOIS”, no estamos refiriendo a eso, sino a comprender quienes son los que manejan y exponen las bases de direccionamiento en el mundo.

Los datos que se puedan obtener, son necesarios para realizar un reconocimiento de quienes son los dueños de un sitio, servicio, etc.

## Explicando: Direccionamiento IP

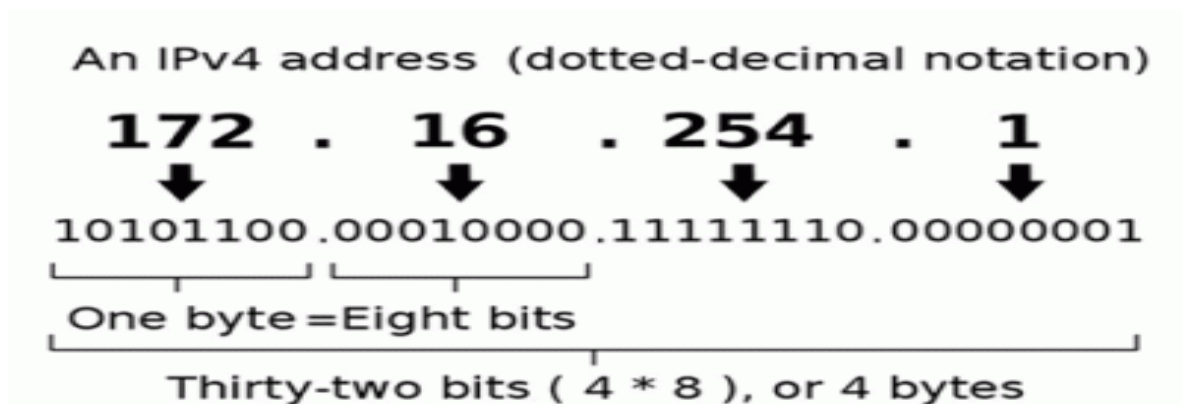
Las direcciones IPv4 se interpretan SIEMPRE como un número binario de 32 bits, permitiendo un espacio de direcciones de hasta 4.294.967.296 ( $2^{32}$ ) direcciones posibles (Binario= 0 y 1).

Cada dirección *IP* se expresa como números de notación decimal: se dividen los 32 bits de la dirección en cuatro octetos.

**[xxx].[xxx].[xxx].[xxx] Decimal**

**[xxxxxxxx].[xxxxxxxx].[xxxxxxxx].[xxxxxxxx] Binario**

También interpretamos que una dirección IP está compuesta por 4 bytes.



El valor decimal de cada octeto está comprendido en el rango de 0 a 255 [el número binario de 8 bits más alto es 11111111 y esos bits, de derecha a izquierda, tienen valores decimales de 1, 2, 4, 8, 16, 32, 64 y 128, lo que suma 255].

|       |       |       |       |       |       |       |       |       |
|-------|-------|-------|-------|-------|-------|-------|-------|-------|
| 1     | 1     | 1     | 1     | 1     | 1     | 1     | 1     |       |
| $2^7$ | $2^6$ | $2^5$ | $2^4$ | $2^3$ | $2^2$ | $2^1$ | $2^0$ |       |
| 128   | 64    | 32    | 16    | 8     | 4     | 2     | 1     | = 255 |
| 1     | 1     | 0     | 0     | 0     | 0     | 0     | 0     |       |
| $2^7$ | $2^6$ |       |       |       |       |       |       |       |
| 128   | 64    |       |       |       |       |       |       | = 192 |
| 1     | 0     | 1     | 0     | 1     | 1     | 0     | 0     |       |
| $2^7$ |       | $2^5$ |       | $2^3$ | $2^2$ |       |       |       |
| 128   |       | 32    |       | 8     | 4     |       |       | = 172 |

Vamos a realizar un ejemplo:

**192.168.16.24**

Si tomamos el primer octeto (192) en binario seria:

**1 1 0 0 0 0 0 0**

**1    1    0    0    0    0    0    0**

-----

**128   64   32   16   8   4   2   1**

Se suma siempre desde la izquierda a derecha y formando el número solicitado ( $128+64 = 192$ )

Sigamos con el ejemplo, ahora tomemos el segundo octeto (168) en binario sería:

**1 0 1 0 1 0 0 0**

**1    0    1    0    1    0    0    0**

-----

**128   64   32   16   8   4   2   1**

Se suma siempre desde la izquierda a derecha y formando el número solicitado ( $128+32+8 = 168$ ).

¿Cómo serían los próximos octetos?

Tomamos el 16:

**0 0 0 1 0 0 0 0**

**0    0    0    1    0    0    0    0**

-----

128   64   32   16   8   4   2   1

Tomamos por último el 24:

**0 0 0 1 1 0 0 0**

0   0   0   1   1   0   0   0

-----

128   64   32   16   8   4   2   1

Otra forma de pasar decimal a binario: dividir siempre por 2

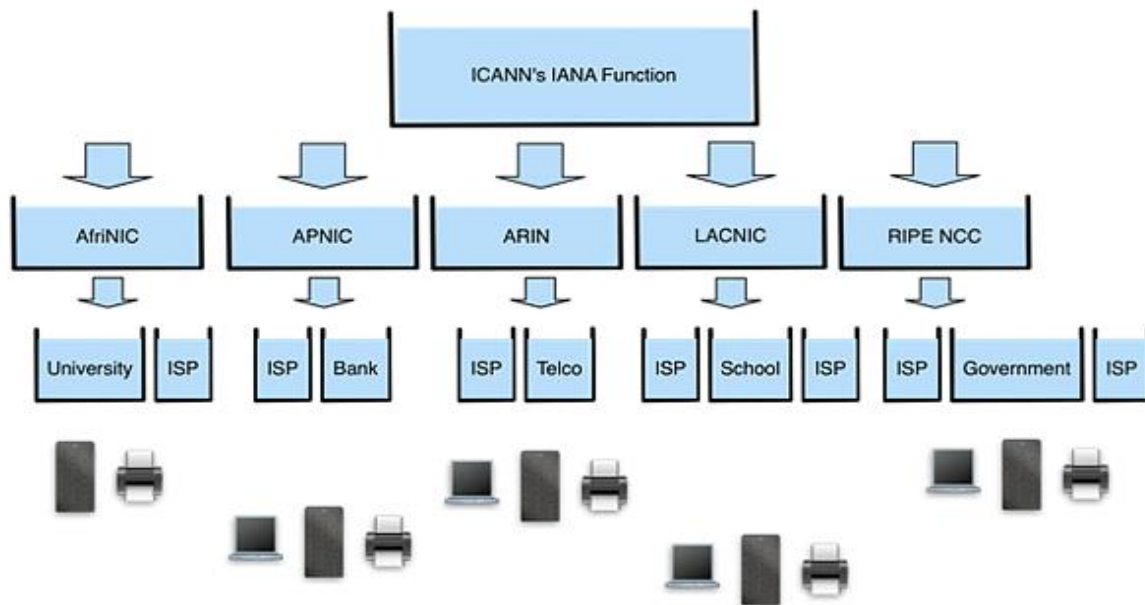
Transformar el número decimal 145 en binario.

145 dividido 2 da 72 y el resto es igual a 1  
72 dividido 2 da 36 y el resto es igual a 0  
36 dividido 2 da 18 y el resto es igual a 0  
18 dividido 2 da 9 y el resto es igual a 0  
9 dividido 2 da 4 y el resto es igual a 1  
4 dividido 2 da 2 y el resto es igual a 0  
2 dividido 2 da 1 y el resto es igual a 0  
1 dividido 2 da 0 y el resto es igual a 1

Ordenando los restos, del último al primero: **10010001**

**Total=145**

El **direccionamiento IP** se gestiona a nivel global por la **corporación ICANN**, que reparte los grandes bloques de direccionamiento a cinco regiones, por lo tanto, la adopción de esta evolución tecnológica afecta a todos los países.



Las direcciones IPs son “públicas”, se pueden acceder desde cualquier lugar del mundo.

Esto hace que dos equipos en el mundo no tengan la misma IP evitando la duplicación de la misma.

Dentro del ambiente direccionamiento “privado”, ya explicamos que nos encontraremos con tres clases:

**Clase A: 10.0.0.0 /8**

**Clase B: 172.16.0.0 /16 hasta la 172.31.0.0 /16**

**Clase C: 192.168.0.0 /24 hasta la 192.168.255.0 /24**

## **Veamos una introducción de IPv6:**

El IPv6 es el protocolo estándar de Internet.

Se ha diseñado para actualizar la versión de Ipv4, ya que quedó corto para direccionar todos los hosts en la Internet.

En el IPv6 tenemos una dirección lógica de 128 bits, por lo que abarca un rango mucho más amplio que la dirección IPv4 (esto significa que IPv6 ofrece 1.028 veces más direcciones que IPv4 con solamente 32 bits).

Se visualiza escrita casi siempre en formato hexadecimal (8 segmentos / hexadecatetos):

Ejemplo: **2001:0DB8:12FA:DAFF:FEBC:BEBA:CAFE:CC49**

El IPv6 contiene  $2^{128}$  direcciones diferentes (el IPv4 soporta alrededor de 4,29 mil millones de direcciones).

La cantidad de direcciones únicas para direccionamiento de hosts que ofrece el protocolo IPv6 en su totalidad: 340.282.366.920.938.463.463.374.607.431.768.211.456 (unos 340 undecillones de direcciones IP).

Tiene algunas ventajas frente al IPv4 como reducción de tamaño de encabezado, aumento de tamaño mínimo de paquete a 1280 bytes (contra 576 del IPv4) y agrega encabezados extra que pueden garantizar una capa de seguridad a las transmisiones de datos.

Las direcciones IPv6 se utilizan solamente para referirse a hosts individualmente.

Esa definición se hace por la máscara de subred.

Una máscara de subred determina la cantidad de bits en el direccionamiento que compondrán la porción de red.

La resta de la cantidad total de bits por los de la máscara, determina la cantidad de bits en el direccionamiento que compondrán la porción de host.

**2001:db8::/32 -> 32 bits correspondientes a red.**

**128 - 32 = 96 bits correspondientes a host.**

## **TIPS para interpretar una dirección IPv6**

- 1- Disponemos de una dirección IPV6 (observarla)
- 2- Se encuentra compuesta por 128 bits
- 3- Se define como 8 octetos de 16 bits cada uno
- 4- Cada octeto, se encuentra compuesto por un valor hexadecimal
- 5- Cada dígito está formado por 4 bits (formato binario)
- 6- Los valores Hexadecimales son: 0,1,2,3,4,5,6,7,8,9,A,B,C,D,E,F
- 7- Los primeros 64 bits, identifican la red (GLOBAL PREFIX)
- 8- De estos últimos, los 16 bits finales se utilizan para realizar SUBNET
- 9- Los segundos 64 bits, identifican el host (HOST-ID o INTERFACE-ID)

### ***Método de resumen:***

Ejemplo: dada ***FE00:0000:0000:0001:0000:0000:0021:0234***

### ***Se puede resumir así:***

***FE00:0:0:1:0:0:21:234***

Se resumen los «0», identificando que como es 0 en todo el bit, es nulo.

También se puede utilizar el «:» en un solo intento

***FE00:0:0:1::21:234***

Otra opción sería: ***FE00::1:0:0:21:234***

## Ejercicio Número 2 Unidad 2



Buscar en Internet 2 direcciones IPv4 y 2 IPv6 y examinarlas.

¿Cómo buscarlas?

Es sencillo, haga un ping al sitio seleccionado, por ejemplo, en la ventana de comandos (o solo símbolo de sistemas) escriben:

Ping [www.ejemplo.com](http://www.ejemplo.com) y la conversión expondrá cual es la IP Pública del sitio.

Transformar las IPv4 a binario y subirlas al foro correspondiente.

**Tabla aporte:**

|                  |                 |                 |                 |                 |                |
|------------------|-----------------|-----------------|-----------------|-----------------|----------------|
| <b>0 - 127</b>   | <b>01001011</b> | <b>00111101</b> | <b>10101001</b> | <b>01000100</b> | <b>Clase A</b> |
| <b>128 - 191</b> | <b>10011011</b> | <b>00111101</b> | <b>10101001</b> | <b>01000100</b> | <b>Clase B</b> |
| <b>192 - 223</b> | <b>11011011</b> | <b>10001111</b> | <b>10101001</b> | <b>01000100</b> | <b>Clase C</b> |

| Primer octeto |                  | Direcciones IP |                |               |                      |                            |
|---------------|------------------|----------------|----------------|---------------|----------------------|----------------------------|
| Primeros bits | Rango de valores | CLASE          | Máscara de red | Red y máquina | Número de Redes      | Número de máquinas ó hosts |
| 0             | 0-127            | A              | 255.0.0.0      | N.h.h.h       | $2^7 = 128$          | 16.777.214                 |
| 10            | 128-191          | B              | 255.255.0.0    | N.N.h.h       | $2^{14} = 16.384$    | 65.534                     |
| 110           | 192-223          | C              | 255.255.255.0  | N.N.N.h       | $2^{21} = 2.097.152$ | 254                        |
| 1110          | 224-239          | D              | No aplicable   | Reservado     | No aplicable         | No aplicable               |
| 1111          | 240-255          | E              | No aplicable   | Reservado     | No aplicable         | No aplicable               |

# Seguridad en redes

Dentro de una red, encontraremos maneras de poder securizar la misma, mediante la instalación y configuración de dispositivos que cumplen con las medidas necesarias brindando un comportamiento de cuidado en la red.



Dispositivos como: **Firewall** / **IDS** / **IPS** / **NIDS** / **HIDS** / **WAF**

También en los routers y switches, existen configuraciones y appliances que nos brindarían esa seguridad.

Dentro de estos dispositivos, por ejemplo, existe lo que se llama **ACL** (access-list), que nos da la posibilidad de negar o permitir un determinado servicio o comunicación en la red.

El **Firewall** es un dispositivo de red, donde su función principal es la de bloquear todo acceso hacia la red y desde ella, mediante configuraciones llamadas “reglas o políticas”.

El mismo trabaja revisando todo tráfico especificado y comparándolo con la lógica de permitir o negar según criterios de comportamiento.

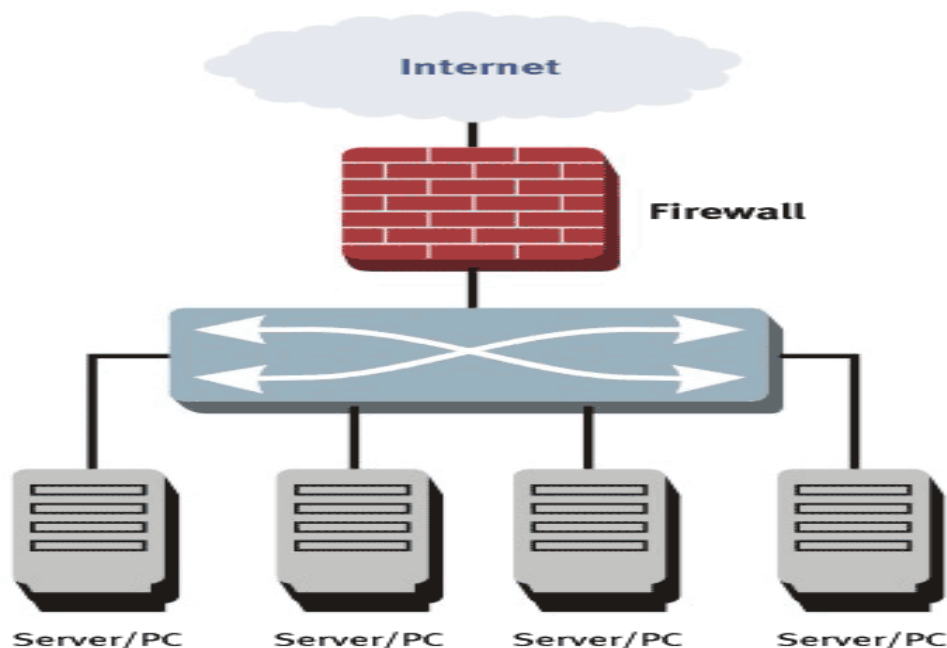
**Restringitivo:** lo que no sea explícitamente permitido, será negado.

**Permisivo:** lo que no sea explícitamente negado, será permitido.

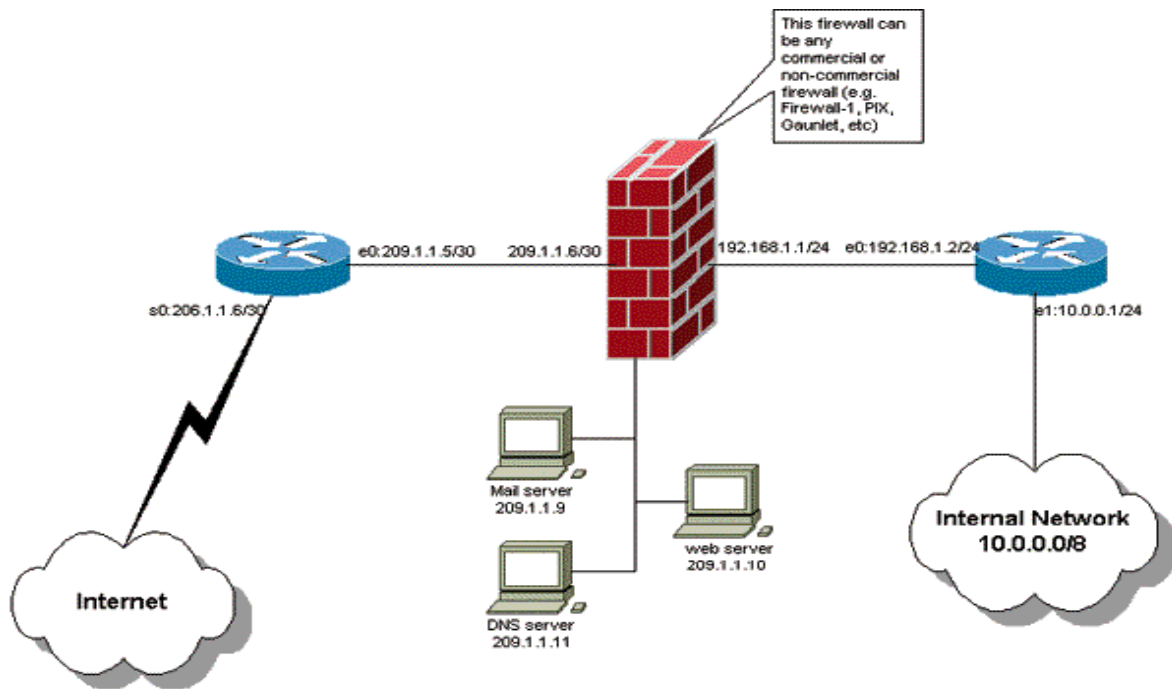
Un **firewall** puede ser no solamente un dispositivo de red, sino que también lo podemos encontrar mediante un software de un sistema operativo, cumpliendo igualmente la función de permitir o negar.

Donde se instale el **firewall**, nos indicará como intermedia las comunicaciones de la red que desea inspeccionar o proteger.

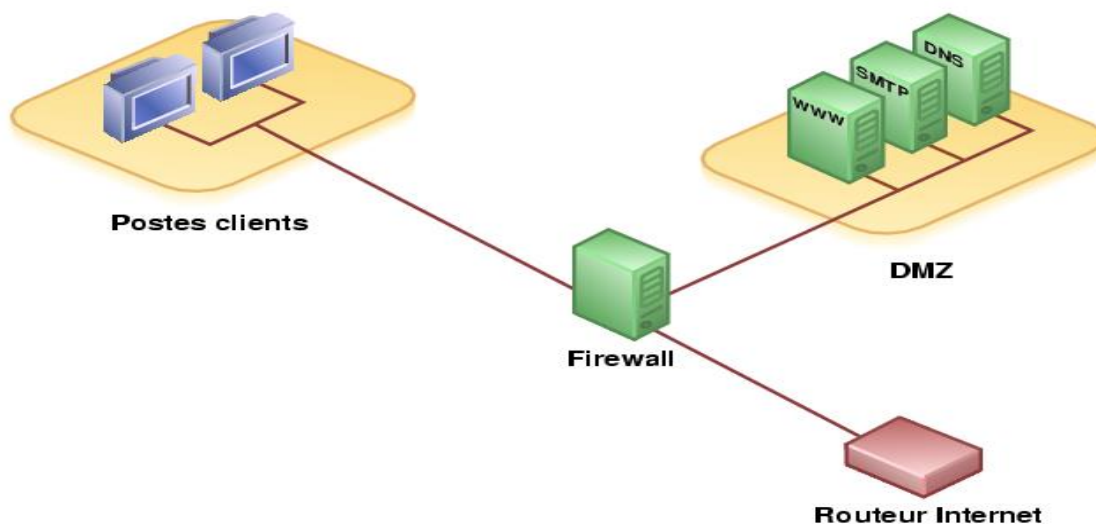
□ **DUAL-HOMED FIREWALL:** el equipo cuenta con dos dispositivos o interfaces, que permitirán interactuar tanto con la red pública como con la privada.



□ MULTI-HOMED FIREWALL: el equipo cuenta con varios dispositivos, que permitirán interactuar con varias redes distintas, dando la posibilidad de implementar políticas y reglas diferentes para cada una.



□ DMZ: una **zona desmilitarizada** (*demilitarized zone*) o **red perimetral** es una red local que se ubica entre la red interna de una organización y una red externa, generalmente Internet.



Uno de los objetivos de una **DMZ** es que las conexiones desde la red interna y la externa a la DMZ estén permitidas

Generalmente se posicionan en esa **DMZ**, los servicios que se quieren publicar en una red pública (Internet) como servidores de correo electrónico, Web y DNS

Dentro de la familia de los **FIREWALLS**, también podemos encontrar servicios tales como **packet filtering** (filtrado de paquetes), **application layer** (análisis de capas) y **statefull** (recuerdo de sesiones establecidas)

Otro elemento que se puede encontrar y ayudarnos a “censar” el tipo de tráfico que tengamos en la red es el **IDS (Intrusion Detection Systems)**

Mediante el análisis de cada paquete que esté circulando dentro de su rango de cobertura, tiene la capacidad de detectar anomalías o firmas, dando la posibilidad de programar reglas.

Un **IDS basado en patrones**, analiza paquetes en la red y los compara con patrones de ataques conocidos, y preconfigurados. Estos patrones se denominan firmas.

Debido a esta técnica, existe un periodo de tiempo entre el descubrimiento del ataque y su patrón, hasta que este es finalmente configurado en un **IDS**. Durante este tiempo, el **IDS** será incapaz de identificar el ataque.

Un **IDS basado en heurística**, determina actividad normal de red, como el orden de ancho de banda usado, protocolos, puertos y dispositivos que generalmente se interconectan, y alerta a un administrador o usuario cuando este varía de aquel considerado como normal, clasificándose como anómalo.

Cuenta con una base de datos (firmas) de donde basándose en la técnica de “censar” paquetes, los compara y actúa en consecuencia, respetando los parámetros asignados a los que se configuran (envío de alarmas, mails, etc.).

## ¿QUE HACEN LOS IDS?

- **Reconfiguración de dispositivos externos (firewalls o ACL en routers)**

Comando enviado por el N-IDS a un dispositivo externo (como un filtro de paquetes o un firewall) para que se reconfigure inmediatamente y así poder bloquear una intrusión. Esta reconfiguración es posible a través del envío de datos que expliquen la alerta (en el encabezado del paquete).

- **Envío de una trampa SNMP a un hipervisor externo**

Envío de una alerta (y detalles de los datos involucrados) en forma de un datagrama SNMP a una consola externa.

- **Envío de un correo electrónico a uno o más usuarios**

Envío de un correo electrónico a uno o más buzones de correo para informar sobre una intrusión sería.

- **Registro del ataque**

Se guardan los detalles de la alerta en una base de datos central, incluyendo información como el registro de fecha, la dirección IP del intruso, la dirección IP del destino, el protocolo utilizado y la carga útil.

- **Almacenamiento de paquetes sospechosos**

Se guardan todos los paquetes originales capturados y/o los paquetes que dispararon la alerta.

- **Apertura de una aplicación:**

Se lanza un programa externo que realice una acción específica (envío de un mensaje de texto SMS o la emisión de una alarma sonora).

- **Notificación visual de una alerta**

Se muestra una alerta en una o más de las consolas de administración.

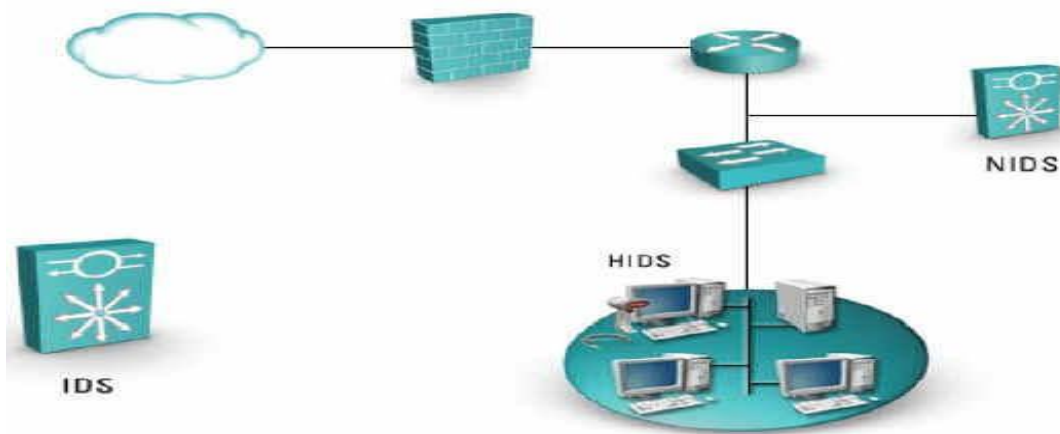


### **Imagen delantera y trasera de un IDS Cisco 4250**

De acuerdo a su estructura, se cuentan con dos tipos que son especiales para redes:

**NIDS:** basados en hardware o software, para analizar segmentos de red donde estén conectados, garantizando la seguridad dentro de una red.

**HIDS:** basado en software, generalmente aplicado sobre el sistema operativo del equipo a proteger, garantizando la seguridad de un host.

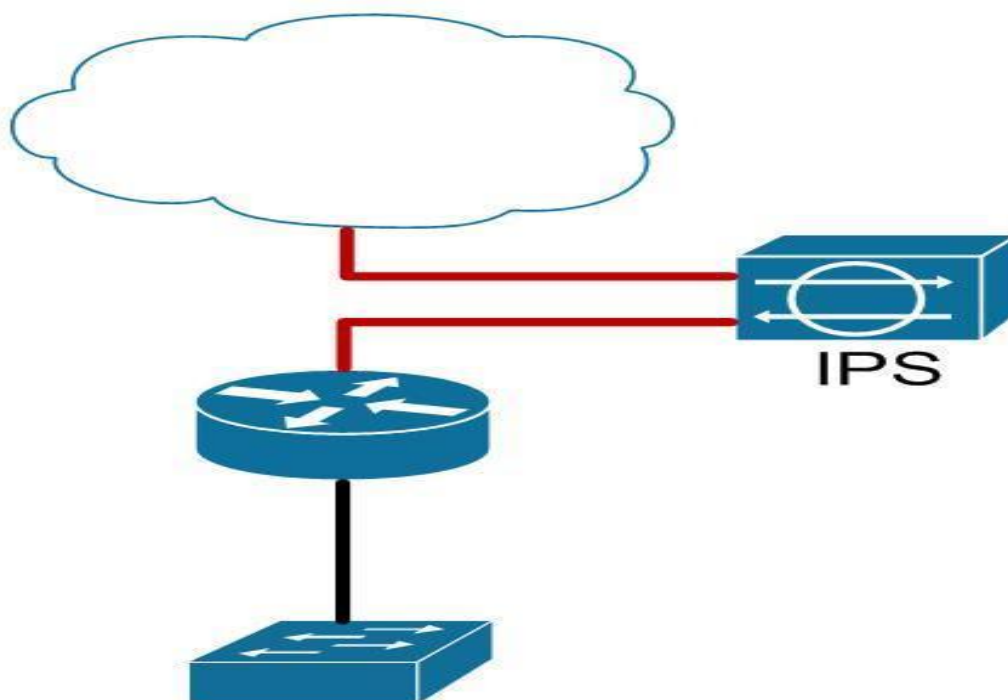


Los **HIDS**, analizan la información almacenada en registros, aparte de capturar paquetes que entran o salen del dispositivo, dando la posibilidad de detectar:

**Ataques de denegación de servicio – Troyanos – Ejecución de códigos maliciosos – Ataques de desbordamiento de buffer – Intentos de acceso no autorizado.**

Y por último tenemos el **IPS (Intrusion Prevention Systems)** que a diferencia de los **IDS**, este analiza en tiempo real, teniendo para contemplar esa posibilidad, un puerto de entrada y otro de salida.

Una de sus funciones más importantes es monitorear el tráfico de red y/o las actividades de un sistema en busca de actividad maliciosa.



Si bien es muy útil, hay que tener en cuenta, que analiza todo tráfico entrante y saliente, basándose en anomalías y firmas, por lo que habrá que hacer un chequeo exhaustivo para que no ocasione problemas de rendimiento en la red.

Cuenta con varios métodos de detección, explicaremos los más importantes:

- **Detección basada en firmas:**

Una firma tiene la capacidad de reconocer una determinada cadena de bytes en cierto contexto. Por ejemplo, los ataques contra los servidores Web generalmente toman la forma de URLs.

Por lo tanto se puede buscar utilizando un cierto patrón de cadenas que pueda identificar ataques al servidor web.

Sin embargo, como este tipo de detección funciona parecido a un antivirus, el administrador debe verificar que las firmas estén constantemente actualizadas.

- **Detección basada en políticas:**

Declarar específicamente las políticas de seguridad.

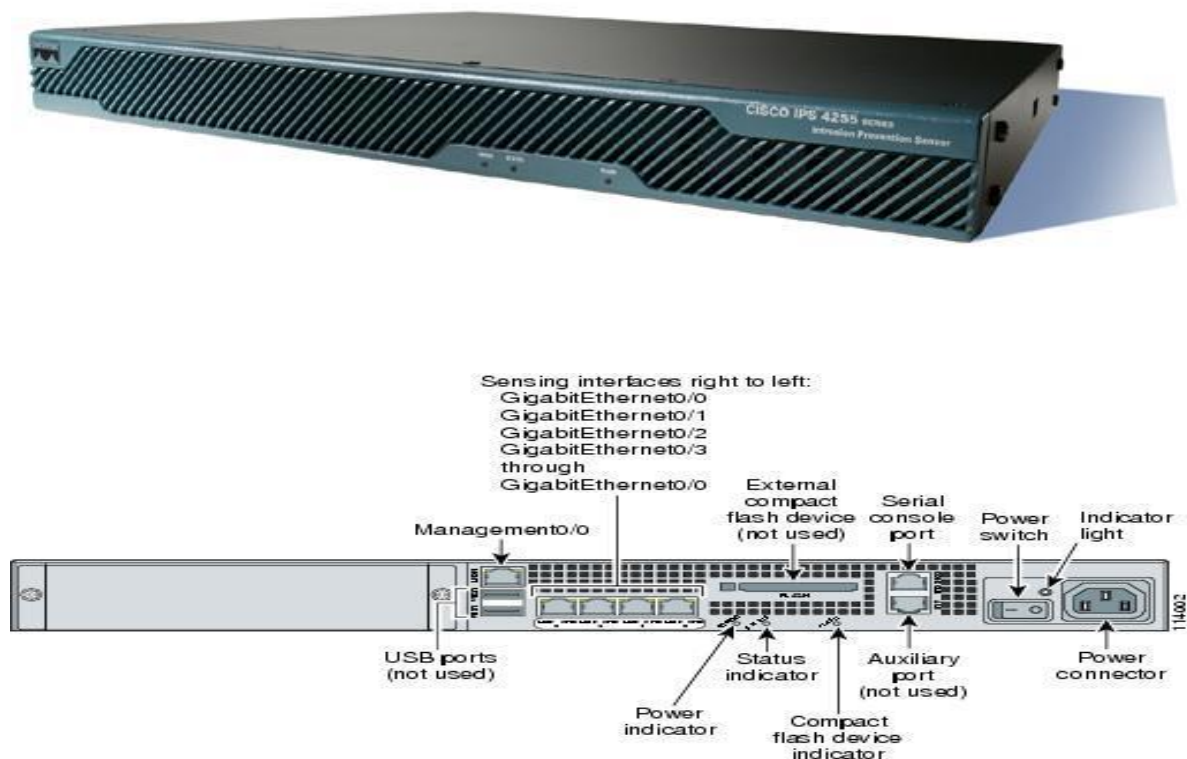
El IPS reconoce el tráfico fuera del perfil permitido y lo descarta.

- **Detección basada en anomalías:**

Se define qué se va entender **como SITUACIÓN NORMAL**.

Detección estadística de anomalías: El **IPS** analiza el tráfico de red por un determinado periodo de tiempo y crea una línea base de comparación. Cuando el tráfico varía demasiado con respecto a la línea base de comportamiento, se genera una alarma.

Detección no estadística de anomalías: En este tipo de detección, es el administrador quien define el patrón «normal» de tráfico. Sin embargo, debido a que con este enfoque no se realiza un análisis dinámico y real del uso de la red, es susceptible a generar muchos falsos positivos.



**Imagen delantera y diagrama trasero de un IPS Cisco 4265**

## ¿Qué es un Honeypot?

Un **honeypot** (en inglés «tarro de miel») es un sistema muy flexible dentro de la seguridad informática, que se encarga de **atraer** y **analizar** el comportamiento de los atacantes en internet, y que provee a un investigador o analista informático forense de una información extremadamente valiosa.

La pregunta sería: ¿para qué puede querer una persona atraer atacantes a su propio sistema? Esto puede resultar muy contradictorio, pero lo que se busca con esta implementación es capturar todo el tráfico de red entrante y conocer todos los detalles acerca de las **tendencias** y **metodologías de ataque** de los atacantes así como los fallos de seguridad en nuestra red con el fin de subsanarlos.

Los **honeypots** pueden ejecutarse bajo cualquier sistema operativo y bajo cualquier servicio. Los servicios configurados determinan los vectores de ataque disponibles para que el intruso comprometa y ponga a prueba el sistema.

## Finalidad de los Honeypots

Estas son algunas de las posibilidades que nos ofrecen los honeypots:

- Desviar y distraer la atención del atacante.
- Detectar y aprender nuevas vulnerabilidades.
- Obtener información sobre el atacante (geolocalización, ip, puertos, etc).
- Obtener tendencias de ataque y países más atacados.
- Detectar nuevas muestras de malware que aún no se conozcan.
- Recopilar y estudiar tendencias de ataque

## Clasificación de Honeypots

Los honeypots se clasifican según su implementación (virtual o física) y su nivel de interacción (baja, media, alta).

### SEGÚN SU IMPLEMENTACIÓN:

- **Para producción:** Al implementar un **honeypot** en una red de producción, el objetivo principal es la obtención de información sobre técnicas empleadas para tratar de vulnerar los sistemas que componen dicha infraestructura.

- **Para investigación:** Por otro lado, en este caso los **honeypots** constituyen recursos educativos de naturaleza demostrativa cuyo fin es recopilar la mayor cantidad de información que permita al investigador poder analizar las nuevas tendencias y métodos de ataque así como los distintos objetivos atacados y orígenes de los ataques.

## SEGÚN SU INTERACCIÓN:

- **Alta interacción:** Este tipo de **honeypots** se trata de un sistema convencional, construidos con máquinas reales como el que podría utilizar cualquier usuario.

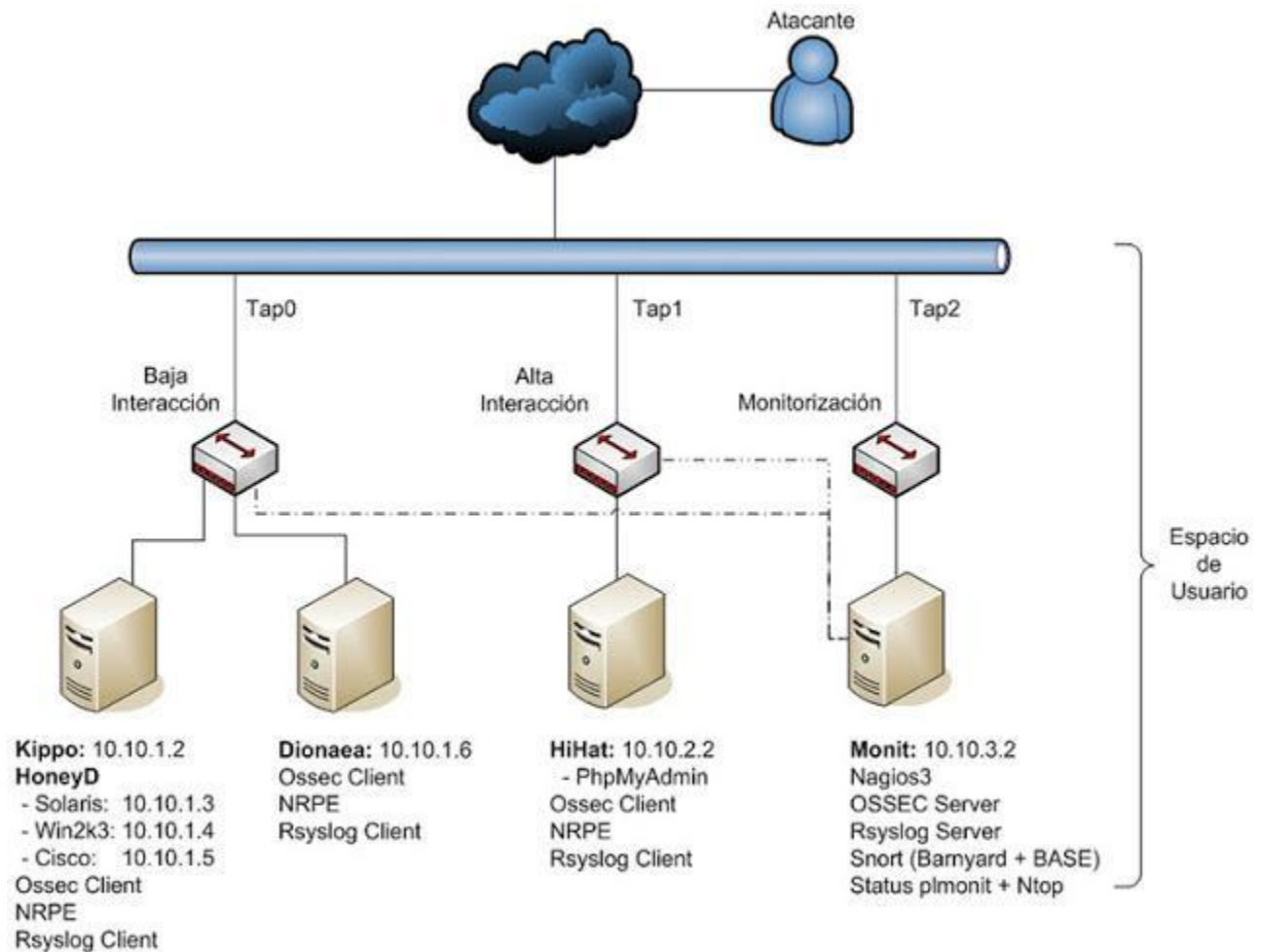
Se sitúan generalmente en la red interna en producción y no tiene más utilidad que la de ser atacados, lo cual significa que el sistema está mal configurado.

Cada interacción con este honeypot se considera sospechosa por definición, y todo el tráfico debe ser monitorizado y almacenado en una zona segura de la red a la que un potencial atacante no tenga acceso.

- **Baja interacción:** Este tipo suele ser creado y gestionado por organizaciones dedicadas a la investigación de acciones fraudulentas en la red, con la cual se investiga acerca de nuevas amenazas en la red.

Son más fáciles de utilizar y mantener, con un riesgo prácticamente nulo.

Esta implementación se basa por lo general en una instalación de software de emulación de sistema operativo, utilizando herramientas conocidas como VMware o Virtual Box.



En esta gráfica, podemos observar diversos sistemas de seguridad y monitoreo, lo cual expone que un atacante una vez ingrese a este tipo de sistemas, podría quedar asentado toda actividad maliciosa.

### **Ejercicio Número 3 Unidad 2**



Realizar un gráfico con una topología a gusto del alumno/a que contenga mínimo:

**10 equipos (PCs)**

**2 switches**

**2 firewalls**

**1 IDS y 1 IPS**

**Una nube de proveedor de servicio (ISP)**

Hay aplicaciones como EDRAW o Packet Tracer para poder dibujar redes, las mismas las pueden conseguir en Internet de forma gratuita.

Lo que se busca en este ejercicio es dibujar las conexiones de acuerdo a un orden de prioridades y explicarlas, por ejemplo, si pongo un FW en tal lugar, cuál sería su función en la misma.

Se respetará la interpretación de cada uno, siempre y cuando la misma se explique en el ejercicio por el alumno.

## **Cómo presentar los ejercicios de la unidad**

Hay dos tipos de ejercicios, los de la unidad (QUE NO SON OBLIGATORIOS) y los que se exponen como obligatorios (que son los finales de cada módulo)

La idea está en que cada uno pueda desarrollar todos los ejercicios y expresarlos en un archivo .doc o .pdf y lo suba al correspondiente foro que estará habilitado.

En el mismo, el formato del archivo será apellido\_UnidadX.doc (donde apellido será el de cada uno y la “X” el número de la unidad de los ejercicios)

Esto significa que en un solo archivo deberían estar todos los ejercicios de la unidad correspondiente, así centralizamos lo de cada uno.

Es muy IMPORTANTE que realicen todos los ejercicios (aun no siendo obligatorios) ya que, al ser un curso a distancia, es una herramienta para saber si hubo una buena comprensión de la unidad.

Luego los mismos serán revisados por el instructor, por eso es importante que lo hagan pronto, para que no se les sume ejercicios de otras unidades.

Pueden ser revisados por todos los demás alumnos e instructor para dar puntos de vista, ayuda o guía.

### **Los ejercicios de esta unidad no llevan calificación**

Los únicos ejercicios que tienen puntuación son los finales, que se realizan cada 4 unidades, pero más adelante se hablará de esto.



## Bibliografía utilizada y sugerida

Harrington, J.(2006) Manual práctico de seguridad de redes. Editorial Anaya Multimedia. México

Hush J.(2020) Redes Informáticas Para Principiantes: La Guía Completa de la Tecnología Inalámbrica, La Seguridad de Redes, Arquitectura de Las Computadoras Y Los Sistemas de Comunicación. Editorial Charlie Creative Lab. España

Dorsel, R.(2020) Hacking for Beginners: Mastery Guide to Learn and Practice the Basics of Computer and Cyber Security. Editorial Charlie Creative Lab. EEUU

Trew, P.(2020) Kali Linux Hacking: A Complete Guide to Learn the Fundamentals of Hacking, Cyber Security, and Penetration Testing. Editorial Charlie Creative Lab. EEUU

Knox, J.(2020) Computer Hacking. Editorial Charlie Creative Lab. EEUU

## Link complementarios:

<https://www.cisco.com/>

<https://www.netacad.com/es/>

En caso de que los links que se exponen no funcionen, por favor avisar al instructor (es normal que un sitio pueda cambiar su URL, dominio o variables, lo cual como la unidad se prepara a principio de año podría suceder que se haya modificado)



Módulo 1:

## **Diseño de redes seguras**

Unidad 3:

### **Redes informáticas – Potenciales Riesgos**



## Presentación

En esta tercer Unidad del curso, nos introducimos en la comprensión de la temática correspondiente a lo que hay que tener en cuenta con respecto a los potenciales ataques.

Comprender los servicios que se utilizan y a la vez, como esos mismos servicios son vulnerables.

También se verán varios laboratorios, que dejarán en claro, la importancia tanto de comprender cómo de utilizar los servicios de Red.



# Objetivos

Que los participantes logren...

- Conocer los conceptos generales de las redes de comunicación, los protocolos, los diferentes dispositivos y sus funciones.
- Aprender a planear, diseñar, estructurar e implementar una infraestructura de red informática de manera segura, protegiéndola de potenciales amenazas.



## Bloques temáticos

1. Amenazas y ataques.
2. Servicios de Red.
3. Potenciales Ataques (LAB).

# Amenazas y Ataques



Las amenazas a la seguridad de la información atentan contra su confidencialidad, integridad y disponibilidad.

Existen amenazas relacionadas con fallas humanas, con ataques malintencionados o con catástrofes naturales.

Mediante la materialización de una amenaza podría ocurrir el acceso, modificación o eliminación de información no autorizada; la interrupción de un servicio o el procesamiento de un sistema; daños físicos o robo del equipamiento y medios de almacenamiento de información.

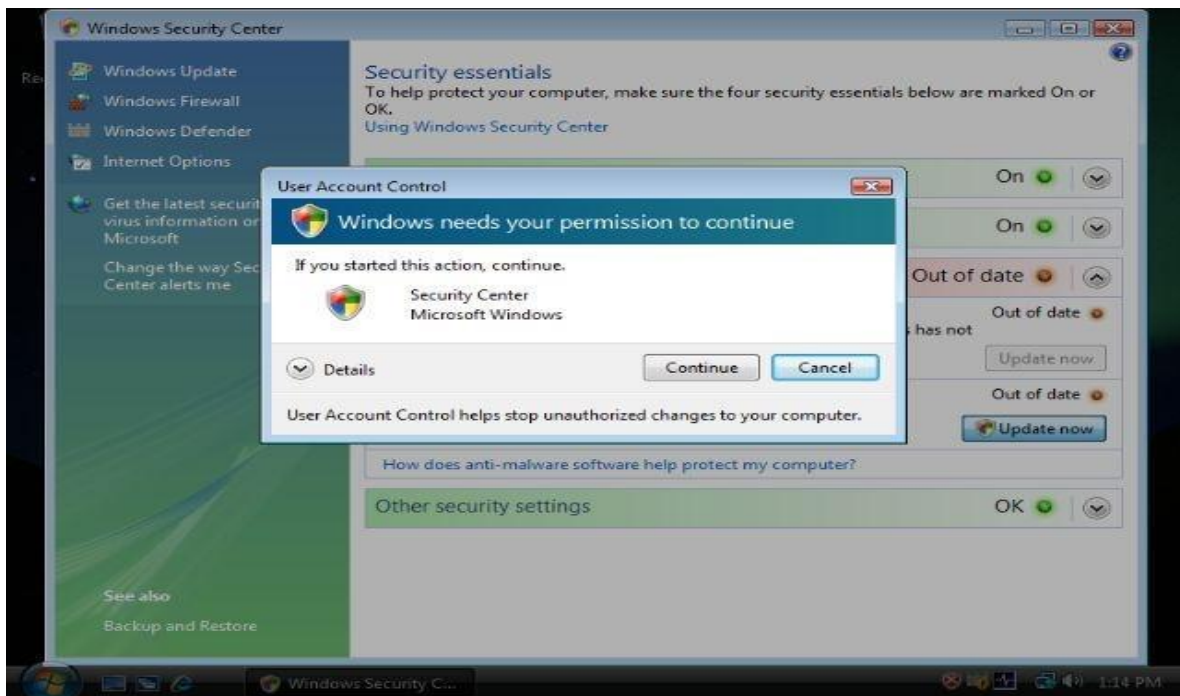
Los protocolos de comunicación utilizados carecen de elementos relacionados con la seguridad o han sido implementados tiempo después de su creación.

Nos encontraremos con:

- **Agujeros de seguridad en sistemas operativos**
- **Agujeros de seguridad en aplicaciones**
- **Errores en las configuraciones de los sistemas**
- **Usuarios que carecen de información**

**Expliquemos los más relevantes:**

Agujeros de seguridad (vulnerabilidades) en sistemas operativos



**CONSECUENCIA:** no se necesitó demasiado tiempo para que apareciera un *script* de **Visual Basic** haciéndonos pasar por el usuario que desactiva el UAC, agregara un ejecutable en la sección de Inicio de Windows, y reiniciará el sistema.

Sitios como **Exploit-DB** o **Security Focus**, informan los distintos agujeros (vulnerabilidades) que pueden tener los sistemas operativos.

Para la forma de mitigación, se necesita siempre estar al tanto de las actualizaciones y parchear los sistemas operativos, de esa forma uno no estaría expuesto, al menos con la vulnerabilidad declarada.

Una recomendación para comprender la importancia, es instalar un sistema operativo en una máquina virtual y llevar a cabo estadísticas de cada vez que se necesite actualizar, de esa manera entenderemos que no es una vez por mes, sino mucho más de lo que uno imagina.

## Agujeros de seguridad (vulnerabilidades) en aplicaciones

Primero observemos estas Estadísticas de los Sistemas y aplicaciones más vulnerables

### Top 50 Products By Total Number Of "Distinct" Vulnerabilities in 2024

Go to year: [2015](#) [2016](#) [2017](#) [2018](#) [2019](#) [2020](#) [2021](#) [2022](#) [2023](#) [2024](#) [2025](#) [All Time Leaders](#)

|    | Product Name                             | Vendor Name               | Product Type | Number of Vulnerabilities |
|----|------------------------------------------|---------------------------|--------------|---------------------------|
| 1  | <a href="#">Linux Kernel</a>             | <a href="#">Linux</a>     | OS           | 3248                      |
| 2  | <a href="#">Windows Server 2022 23h2</a> | <a href="#">Microsoft</a> | OS           | 588                       |
| 3  | <a href="#">Windows Server 2019</a>      | <a href="#">Microsoft</a> | OS           | 582                       |
| 4  | <a href="#">Windows Server 2022</a>      | <a href="#">Microsoft</a> | OS           | 582                       |
| 5  | <a href="#">Windows 11 22h2</a>          | <a href="#">Microsoft</a> | OS           | 539                       |
| 6  | <a href="#">Windows 11 23h2</a>          | <a href="#">Microsoft</a> | OS           | 536                       |
| 7  | <a href="#">Windows 10 22h2</a>          | <a href="#">Microsoft</a> | OS           | 515                       |
| 8  | <a href="#">Windows 10 21h2</a>          | <a href="#">Microsoft</a> | OS           | 507                       |
| 9  | <a href="#">Macos</a>                    | <a href="#">Apple</a>     | OS           | 507                       |
| 10 | <a href="#">Windows Server 2016</a>      | <a href="#">Microsoft</a> | OS           | 495                       |
| 11 | <a href="#">Android</a>                  | <a href="#">Google</a>    | OS           | 492                       |
| 12 | <a href="#">Windows 10 1809</a>          | <a href="#">Microsoft</a> | OS           | 489                       |
| 13 | <a href="#">Windows 11 21h2</a>          | <a href="#">Microsoft</a> | OS           | 450                       |
| 14 | <a href="#">Windows Server 2012</a>      | <a href="#">Microsoft</a> | OS           | 412                       |
| 15 | <a href="#">Windows 10 1607</a>          | <a href="#">Microsoft</a> | OS           | 401                       |
| 16 | <a href="#">Windows 10 1507</a>          | <a href="#">Microsoft</a> | OS           | 378                       |
| 17 | <a href="#">Iphone Os</a>                | <a href="#">Apple</a>     | OS           | 316                       |
| 18 | <a href="#">Experience Manager</a>       | <a href="#">Adobe</a>     | Application  | 313                       |
| 19 | <a href="#">Windows Server 2008</a>      | <a href="#">Microsoft</a> | OS           | 295                       |
| 20 | <a href="#">Ipados</a>                   | <a href="#">Apple</a>     | OS           | 280                       |

Fuente: <https://www.cvedetails.com/top-50-products.php?year=2024>

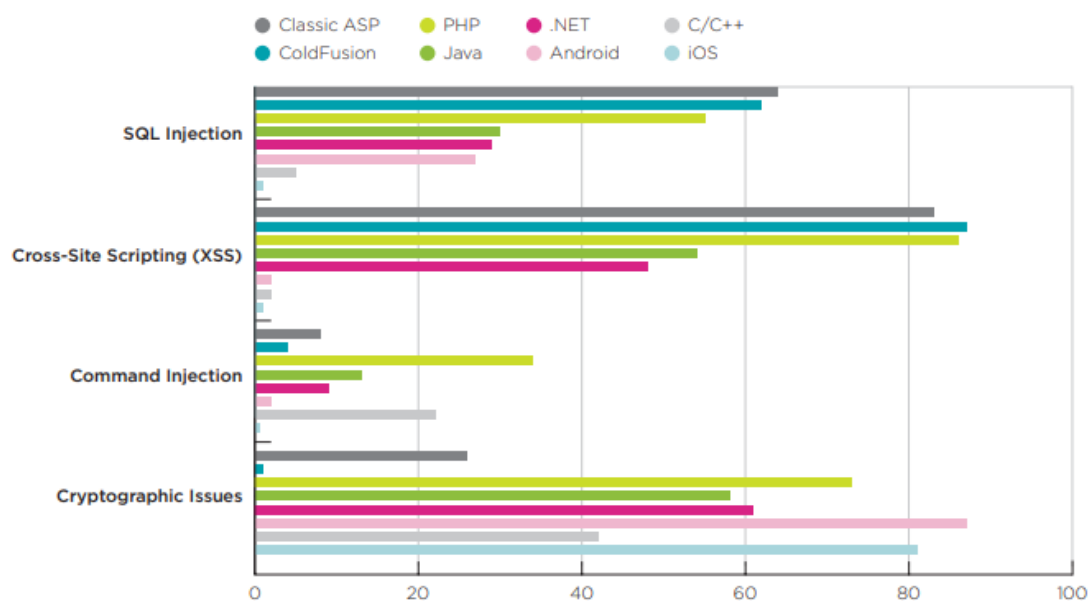
En estos casos, mantenerse informado sobre cómo las aplicaciones más conocidas es un punto positivo, para estar enterado de cuándo actualizar.

Se recomienda realizar un relevamiento completo de las aplicaciones que uno tiene, y a partir de ahí, chequear y analizar si existe la posibilidad de actualizarlas.



## Estadísticas de los lenguajes de programación más vulnerables

Estos son los más buscados por los atacantes, ya que son errores propios de programación y la vulnerabilidad encontrada puede llegar a ser tomar control completo de un sistema o aplicación.



| Language | CWE Category                  | Apps Affected |
|----------|-------------------------------|---------------|
| OVERALL  | Code Quality                  | 63%           |
|          | Cryptographic Issues          | 58%           |
|          | Information Leakage           | 56%           |
|          | CRLF Injection                | 49%           |
|          | Directory Traversal           | 47%           |
|          | Cross-Site Scripting (XSS)    | 47%           |
|          | Insufficient Input Validation | 37%           |
|          | SQL Injection                 | 29%           |
|          | Credentials Management        | 25%           |
|          | Time and State                | 23%           |
|          |                               |               |
| .NET     | Information Leakage           | 66%           |
|          | Code Quality                  | 64%           |
|          | Cryptographic Issues          | 61%           |
|          | Directory Traversal           | 56%           |
|          | Cross-Site Scripting (XSS)    | 48%           |
|          | Insufficient Input Validation | 46%           |
|          | CRLF Injection                | 38%           |
|          | SQL Injection                 | 29%           |
|          | Time and State                | 20%           |
|          | Credentials Management        | 16%           |

| Language    | CWE Category                  | Apps Affected |
|-------------|-------------------------------|---------------|
| ANDROID     | Code Quality                  | 90%           |
|             | Cryptographic Issues          | 87%           |
|             | CRLF Injection                | 79%           |
|             | Information Leakage           | 47%           |
|             | Directory Traversal           | 33%           |
|             | Time and State                | 28%           |
|             | Authorization Issues          | 28%           |
|             | SQL Injection                 | 27%           |
|             | Insufficient Input Validation | 26%           |
|             | Credentials Management        | 22%           |
| CLASSIC ASP | Cross-Site Scripting (XSS)    | 83%           |
|             | SQL Injection                 | 64%           |
|             | Insufficient Input Validation | 59%           |
|             | Information Leakage           | 58%           |
|             | Directory Traversal           | 47%           |
|             | Session Fixation              | 41%           |
|             | Credentials Management        | 29%           |
|             | CRLF Injection                | 24%           |
|             | Command or Argument Injection | 24%           |
|             | Code Injection                | 20%           |

| Language    | CWE Category                  | Apps Affected |
|-------------|-------------------------------|---------------|
| C++         | Error Handling                | 75%           |
|             | Buffer Overflow               | 56%           |
|             | Buffer Management Errors      | 53%           |
|             | Numeric Errors                | 50%           |
|             | Cryptographic Issues          | 42%           |
|             | Directory Traversal           | 42%           |
|             | Potential Backdoor            | 37%           |
|             | Race Conditions               | 29%           |
|             | Dangerous Functions           | 28%           |
|             | Code Quality                  | 27%           |
|             |                               |               |
| COLD FUSION | Cross-Site Scripting (XSS)    | 87%           |
|             | Information Leakage           | 67%           |
|             | SQL Injection                 | 62%           |
|             | Directory Traversal           | 44%           |
|             | Code Quality                  | 43%           |
|             | Time and State                | 42%           |
|             | Command or Argument Injection | 4%            |
|             | CRLF Injection                | 2%            |
|             | Cryptographic Issues          | 1%            |
|             | API Abuse                     | 1%            |
| IOS         | Error Handling                | 84%           |
|             | Cryptographic Issues          | 81%           |
|             | Credentials Management        | 55%           |
|             | Potential Backdoor            | 50%           |
|             | Information Leakage           | 43%           |
|             | Code Quality                  | 14%           |
|             | API Abuse                     | 14%           |
|             | Buffer Overflow               | 9%            |
|             | Coding Standards              | 6%            |
|             | Buffer Management Errors      | 6%            |

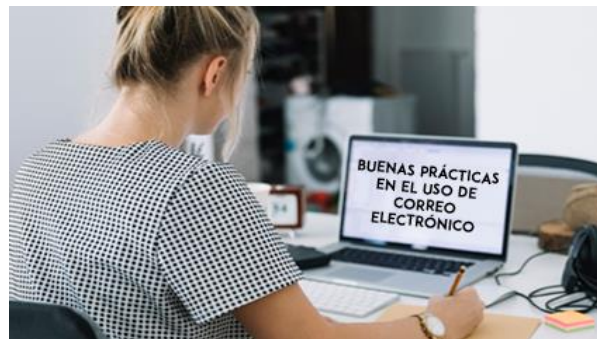
| Language | CWE Category                  | Apps Affected |
|----------|-------------------------------|---------------|
| JAVA     | Code Quality                  | 80%           |
|          | CRLF Injection                | 75%           |
|          | Cryptographic Issues          | 58%           |
|          | Information Leakage           | 57%           |
|          | Cross-Site Scripting (XSS)    | 54%           |
|          | Directory Traversal           | 48%           |
|          | Insufficient Input Validation | 45%           |
|          | Encapsulation                 | 35%           |
|          | API Abuse                     | 32%           |
|          | Time and State                | 31%           |
|          | SQL Injection                 | 21%           |
| PHP      | Cross-Site Scripting (XSS)    | 86%           |
|          | Cryptographic Issues          | 73%           |
|          | Directory Traversal           | 67%           |
|          | Code Injection                | 61%           |
|          | Credentials Management        | 58%           |
|          | SQL Injection                 | 56%           |
|          | Information Leakage           | 50%           |
|          | Command or Argument Injection | 34%           |
|          | Untrusted Initialization      | 30%           |
|          | Code Quality                  | 9%            |

## Usuarios sin conocimientos suficientes (concientización necesaria)

La medida de concientización, es la más importante de todas, lo mismo que aplicar procesos que eviten la fuga de información.



Así como evitar que se realicen prácticas indebidas, por ejemplo, el uso de USB no permitido, o abrir mails desconocidos o clickear a todo lo que salga, sin antes revisar o analizar.



Lo que uno se debe preguntar, de qué sirve aplicar políticas de seguridad si los usuarios no cumplen con los requisitos de conocimientos necesarios.

Una manera sencilla, en la concientización es enseñar al menos, 3 parámetros claves:

- 1- analizar si los mails tienen un destinatario directo, si no se distingue, estamos ante una campaña de envío masivo.
- 2- la historia central, generalmente es un mensaje alarmante o que llama la atención, donde requiere la intervención de la víctima.

3- lo que pide, generalmente propósito económico, contacto bancario, todo lo que pueda ir directo a una estafa, es síntoma.

Debido a su complejidad, se recolectan datos que le dan al atacante las pautas para tener éxito, las más habituales son:

- **Identificación del sistema operativo:**

Los ataques difieren mucho según el sistema operativo que esté instalado en el ordenador

- **Escaneo de protocolos, puertos y servicios:**

Los servicios: Son los programas que carga el propio sistema operativo para poder funcionar, servicio de impresión, actualizaciones automáticas, servicios de chat...

Los puertos son las vías que utiliza el ordenador para comunicarse, 21 es el del FTP, 995 el del correo seguro...

**Protocolos:** Son los diferentes lenguajes establecidos que utiliza el ordenador para comunicarse

De este modo si se escanea todo este entorno el atacante se hace una idea de cómo poder realizar el ataque.

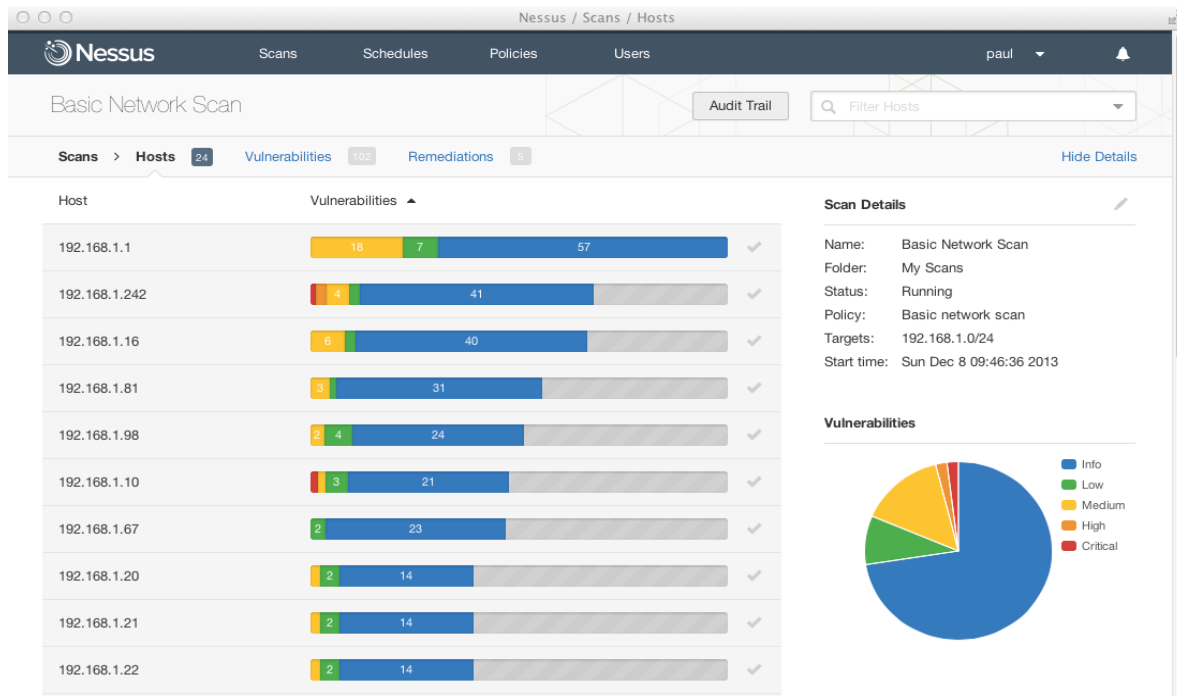
## **Escaneo de vulnerabilidades.**

### **Del sistema operativo**

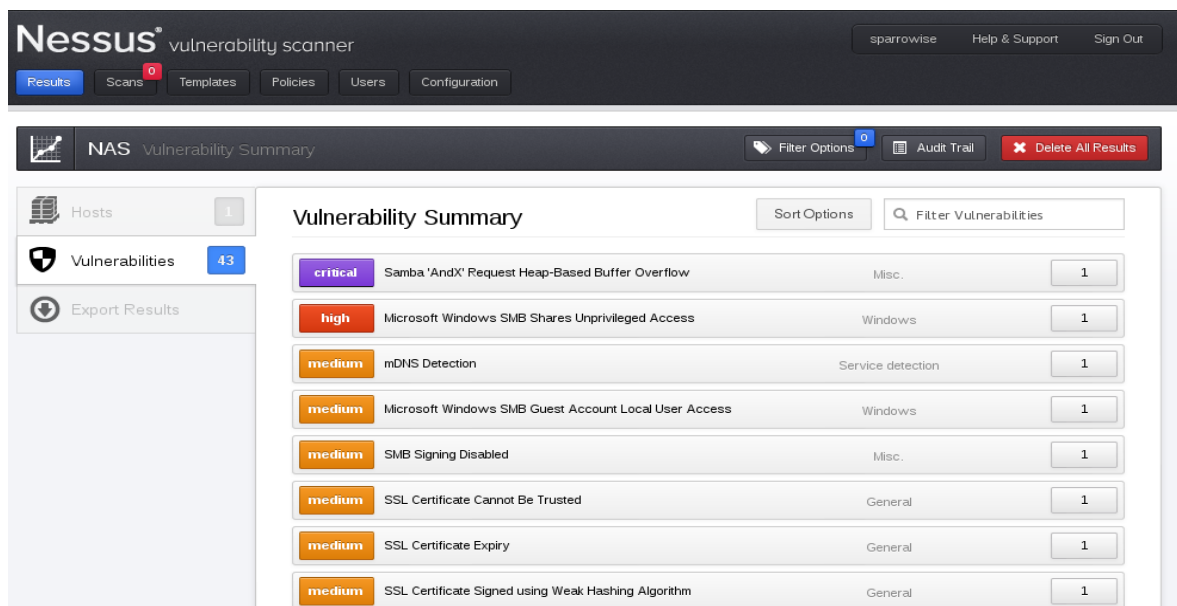
### **De los programas instalados**

Estos 3 parámetros, son los que realizará un atacante para poder detectar cualquier posibilidad de intrusión, si observamos y comprendimos todo lo leído hasta ahora, se sabrá que la solución es mantener una línea de políticas y procesos adecuados para asegurar todos los entornos.

## Un buen scanner de vulnerabilidades para empezar: “NESSUS”



## Ejemplo de captura de resultados





[Partners](#) [Careers](#) [Language](#) [Login](#)

[Products +](#) [Support & Services](#) [Company +](#) [Try/Buy](#)

## Try Nessus Professional Free for 7 Days

Nessus® is the most comprehensive vulnerability scanner on the market today. Nessus Professional will help automate the vulnerability scanning process, save time in your compliance cycles, and allow you to engage your IT team.

|                                 | Nessus Evaluation                                                | Nessus                       |
|---------------------------------|------------------------------------------------------------------|------------------------------|
| Designed For                    | Commercial organizations wanting to evaluate Nessus Professional | Single Users, Commercial Use |
| Real-time Vulnerability Updates | ✓                                                                | ✓                            |

### Register

Please register to evaluate Nessus. An activation code will be emailed to the address you provide.

First Name\*

Last Name\*

Fuente oficial para descargarlo: [www.tenable.com](http://www.tenable.com)

The screenshot shows the OpenVAS website with a navigation bar containing 'About OpenVAS', 'Try out OpenVAS', and 'Support'. A large green button with a white arrow pointing down says 'Download OpenVAS'. To the right, a diagram illustrates the OpenVAS architecture, including components like OpenVAS GUI, OpenVAS Scanner, OpenVAS Manager, OpenVAS Administrator, and OpenVAS Security Assistant. A cartoon character is shown pointing towards the diagram. Below the diagram, there are screenshots of the OpenVAS web interface showing various reports and charts.

The world's most advanced Open Source  
vulnerability scanner and manager

Otro scanner recomendado - Fuente oficial para descargarlo:

[www.openvas.org](http://www.openvas.org)

Que podemos encontrarnos:

- **Identificación vulnerabilidades en Versiones de Aplicación y Sistemas Operativos**
- **Gestión de Parches (Patch Management)**
- **Identificar Vulnerabilidades Tecnológicas y Humanas**
- **Configuraciones por Defecto (Password Default)**
- **Vulnerabilidades Técnicas y Funcionales**

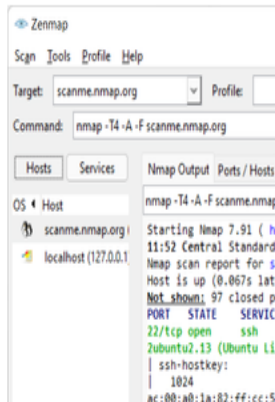
(En otro módulo se verán en detalle estos temas)

Ejemplo de un escaneo de un sistema operativo con el programa NMAP

```
root@kaliLinux: *
Archivo  Editar  Ver  Buscar  Terminal  Ayuda
Completed ARP Ping Scan at 10:17, 0.02s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 10:17
Completed Parallel DNS resolution of 1 host. at 10:17, 0.06s elapsed
Initiating SYN Stealth Scan at 10:17
Scanning 192.168.20.1 [1000 ports]
Discovered open port 111/tcp on 192.168.20.1
Discovered open port 8080/tcp on 192.168.20.1
Discovered open port 53/tcp on 192.168.20.1
Discovered open port 10000/tcp on 192.168.20.1
Discovered open port 8081/tcp on 192.168.20.1
Completed SYN Stealth Scan at 10:17, 0.31s elapsed (1000 total ports)
Nmap scan report for 192.168.20.1
Host is up (0.0019s latency).
Not shown: 995 closed ports
PORT      STATE SERVICE
53/tcp    open  domain
111/tcp   open  rpcbind
8080/tcp   open  http-proxy
8081/tcp   open  blackice-icecap
10000/tcp  open  snet-sensor-mgmt
MAC Address: 08:00:27:8C:A1:90 (Cadmus Computer Systems)

Read data files from: /usr/bin/../../share/nmap
Nmap done: 1 IP address (1 host up) scanned in 0.66 seconds
Raw packets sent: 1001 (44.028KB) | Rcvd: 1001 (40.048KB)
root@kaliLinux:~# nmap -sS -v 192.168.20.1
```

## Microsoft Windows binaries



Please read the [Windows section](#) of the Install Guide for limitations and installation instructions for the Windows version of Nmap. It's provided as an executable self-installer which includes Nmap's dependencies and the Zenmap GUI. We support Nmap on Windows 7 and newer, as well as Windows Server 2008 R2 and newer. We also maintain a [guide for users who must run Nmap on earlier Windows releases](#).

**Note:** The version of Npcap included in our installers may not always be the latest version. If you experience problems or just want the latest and greatest version, download and install [the latest Npcap release](#).

**Latest stable release self-installer:** [nmap-7.95-setup.exe](#)

**Latest Npcap release self-installer:** [npcap-1.80.exe](#)

We have written [post-install usage instructions](#). Please [notify us](#) if you encounter any problems or have suggestions for the installer.

Scanner de puertos y servicios recomendado - Fuente oficial para descargarlo: **[www.nmap.org](http://www.nmap.org)**

---

A través de estos Scanners, es posible detectar vulnerabilidades, fallas en sistemas y aplicaciones, malas configuraciones y posibilidad de detectar intrusiones.

En conclusión existen multitud de tipos de técnicas de ataques de red aunque existen cuatro tipos básicos:

- **Ataques de denegación de servicio**
- **Ataques contra la autenticación**
- **Ataques de modificación y daño a la integridad**
- **Ataques aprovechando deficiencias de seguridad**

### **Ejercicio Número 1 Unidad 3**



Buscar en Internet alguna noticia de un incidente (ataque) informático (no importa el tipo de técnica de ataque) y hacer un análisis personal dando un punto de vista sobre que sucedió y cómo habría que evitarlo de acuerdo a sus conocimientos (postear en el foro de ejercicios).

El mismo queda para que TODOS lean los trabajos de sus compañeros.

**TIPS: sitios recomendados para encontrar noticias**

<https://www.hackmageddon.com/>

<https://www.zdnet.com/topic/security/>

<https://www.redpacketsecurity.com/>

Por favor, en caso de que los links no funcionen, avisar al instructor, ya que es muy común que se cambien, den de baja o se actualice la misma URL.

# Servicios de Red

Dentro de una red, podremos encontrar o agregar servicios relacionados con la seguridad, la protección de datos y la configuración de la red.

Estos servicios nos permiten realizar diferentes tareas.

## **NAT – PAT – ARP – DNS – DHCP**

A continuación analizaremos de forma resumida los mismos, ya que son imprescindibles para lograr establecer una conexión entre equipos.

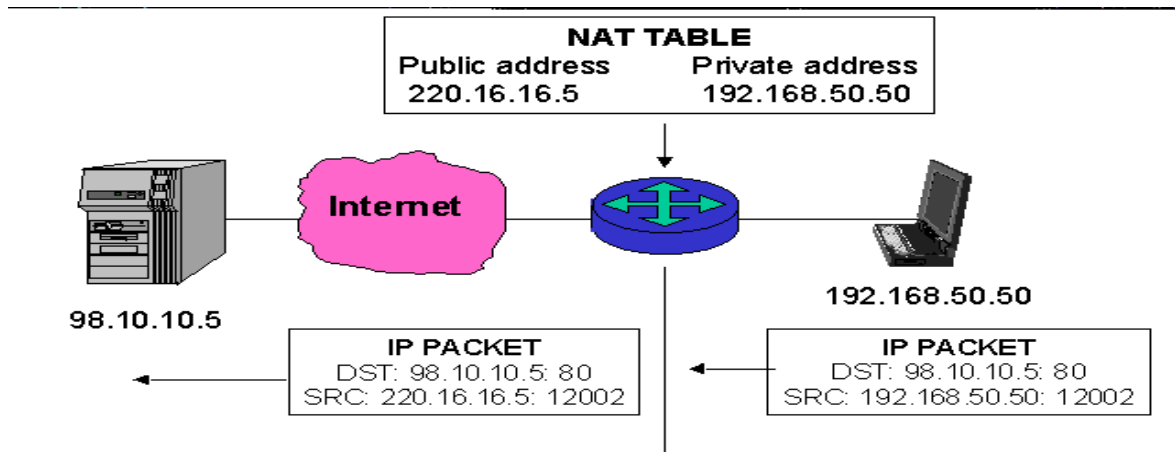
### **NAT (Network Address Translation)**

Es un mecanismo utilizado por routers **IP** para intercambiar paquetes entre dos redes que asignan mutuamente direcciones incompatibles.

El tipo más simple de **NAT** proporciona una traducción una-a-una de las direcciones **IP**.

La mayoría de los **NAT** asignan varias máquinas (hosts) privadas a una dirección **IP** expuesta públicamente.

En conclusión, cada equipo conectado a cada red, se identifica hacia otras redes, con una única **IP PÚBLICA**, teniendo nuestra identificación pública de nuestro **NAT**.



En este ejemplo, vemos que la **IP** 192.168.50.50 (Privada) se identificara en Internet con la **IP** 220.16.16.5 (Publica).

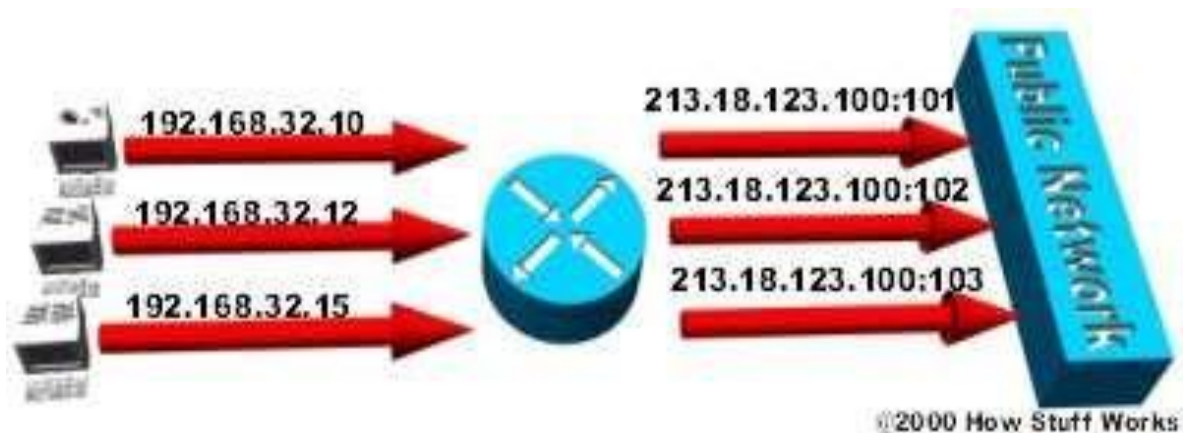
También notamos que quiere llegar a un objetivo **IP** 98.10.10.5 (Privada), el cual recibirá la notificación de la **IP PUBLICA NAT** (220.16.16.5) correspondiente a la **IP Origen PRIVADA**.

## PAT (Port Address Translation)

Es una variante del **NAT**, aquí incorpora asignación dinámica de puertos en cada comunicación entre la red privada y la red pública.

Trabaja en capa 4 (TRANSPORTE) del modelo **OSI**, el **NAT** trabaja en capa 3 (**RED**), ya que solo gestiona direccionamiento **IP**.

A continuación, vemos como traduce 3 direcciones **IP** privadas a 1 única **IP** pública, asignando a cada privada un puerto específico.



## Otro ejemplo de PAT

Tenemos 3 computadoras y cada una tiene un servicio diferente:

**Equipo A: 10.10.10.1 FTP o sea usa el puerto 21**

**Equipo B: 10.10.10.2 HTTP o sea usa el puerto 80**

**Equipo C: 10.10.10.3 TELNET o sea usa el puerto 23**

Y como nuestro router tiene una sola **IP** Pública (200.10.90.17), lo que hará el mismo es asignarle un puerto a cada servicio e **IP**.

**10.10.10.1:21 ----- 200.10.90.17:5001**

**10.10.10.2:80 ----- 200.10.90.17:5002**

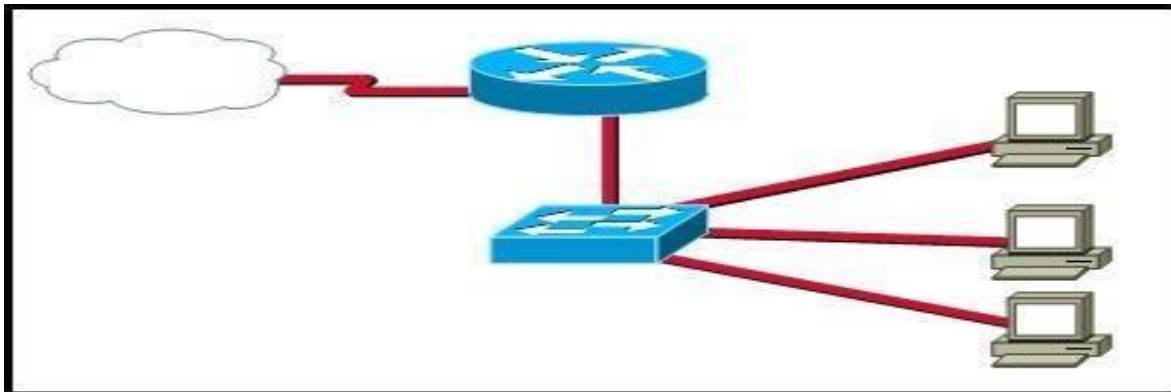
**10.10.10.3:23 ----- 200.10.90.17:5003**

De esta manera presentará a los equipos al exterior.

### Ejercicio Número 2 Unidad 3



Completar con direccionamiento y puertos ficticios, utilizando el protocolo PAT (subirlo al foro de ejercicios)



Se solicita: IPs origen, IPs destino, puerto origen, puerto destino, de cada una de las PCs.

Por otro lado, a nivel WAN, se pide una IP pública y el puerto identificador para cada servicio.

## ARP (Address Resolution Protocol)

Antes sepamos que es una **Mac Address**: es un identificador único de 48 bits para identificar la totalidad de dispositivos de red como por ejemplo tarjetas de red Ethernet, tarjetas de red Wireless o inalámbricas, Switch de red, Routers, impresoras, etc.



Las direcciones MAC son identificadores únicos a nivel mundial para cada dispositivo y por lo tanto es imposible encontrar 2 tarjetas de red o 2 dispositivos de red que tengan la misma Mac Address.

La totalidad de fabricantes en el momento de fabricar el hardware, como por ejemplo una tarjeta de red Wireless, graban la Mac Address en formato binario en una memoria ROM del dispositivo que están fabricando.

Como la memoria ROM es solo de lectura es totalmente imposible modificarla y por lo tanto esto implica que la Mac address o identificador de un dispositivo nunca se podría modificar.

Más adelante veremos que es posible hacer creer a otras personas o a integrantes de la red que nuestra MAC Address es otra diferente a la real (posibilidad de cambiar la MAC).

El motivo por el cual es posible modificar la MAC de la tarjeta de red de nuestra PC es simple.

Cuando se arranca nuestro ordenador la tarjeta de red copia la dirección MAC a nuestra memoria RAM.

Una vez copiada la Mac Address a la memoria RAM la totalidad de veces que se requiere de la Mac Address se usará la Mac Address almacenada en la memoria RAM.

Por lo tanto, si queremos cambiar nuestra Mac Address tan solo tenemos que modificar la Mac Address almacenada en nuestra memoria **RAM**.

Es un protocolo de la capa de enlace de datos responsable de encontrar la dirección hardware (MAC) que corresponde a una determinada dirección IP de un dispositivo de red.

En Ethernet, la capa de enlace trabaja con direcciones físicas.

El protocolo ARP se encarga de traducir las direcciones IP a direcciones MAC (direcciones físicas). Para realizar esta conversión, el nivel de enlace utiliza las tablas ARP, cada interfaz tiene tanto una dirección IP como una dirección física MAC.

```
C:\Users\Laboratorio-01>arp -a

Interfaz: 192.168.56.1 --- 0x15
  Dirección de Internet      Dirección física      Tipo
  192.168.56.255            ff-ff-ff-ff-ff-ff    estático
  224.0.0.22                01-00-5e-00-00-16    estático
  224.0.0.251               01-00-5e-00-00-fb    estático
  224.0.0.252               01-00-5e-00-00-fc    estático
  239.255.255.250           01-00-5e-7f-ff-fa    estático

Interfaz: 10.166.26.1 --- 0x18
  Dirección de Internet      Dirección física      Tipo
  10.204.128.9               02-00-0a-cc-80-09    dinámico
  10.204.160.10              02-00-0a-cc-a0-0a    dinámico
  10.244.10.16               02-00-0a-f4-0a-10    dinámico
  224.0.0.22                01-00-5e-00-00-16    estático
  224.0.0.251               01-00-5e-00-00-fb    estático
  224.0.0.252               01-00-5e-00-00-fc    estático
  239.255.255.250           01-00-5e-7f-ff-fa    estático

Interfaz: 192.168.1.33 --- 0x1d
  Dirección de Internet      Dirección física      Tipo
  192.168.1.1                c8-b4-22-71-12-50    dinámico
  192.168.1.255              ff-ff-ff-ff-ff-ff    estático
  224.0.0.22                01-00-5e-00-00-16    estático
  224.0.0.251               01-00-5e-00-00-fb    estático
  224.0.0.252               01-00-5e-00-00-fc    estático
  239.255.255.250           01-00-5e-7f-ff-fa    estático
  255.255.255.255           ff-ff-ff-ff-ff-ff    estático
```

**Aquí vemos las MAC aprendidas por una PC, usando el comando ARP -A**

## DNS (Domain Name Service)

Cada equipo conectado directamente a Internet tiene al menos una **dirección IP** específica. Sin embargo, los usuarios no desean trabajar con direcciones numéricas, como por ejemplo 194.153.205.26, sino con un nombre de dominio o más específicamente, con direcciones (llamadas direcciones **FQDN**) como por ejemplo es.kioskea.net.

Es posible asociar nombres en lenguaje normal con direcciones numéricas gracias al sistema llamado **DNS** (Sistema de Nombres de Dominio).

Esta correlación entre las direcciones **IP** y el nombre de dominio asociado se llama resolución de nombres de dominio (o resolución de direcciones).

### Introducción al Sistema de Nombres de Dominio:

Este sistema ofrece:

- Un espacio de nombre jerárquico que permite garantizar la singularidad de un nombre en una estructura arbórea.
- Un sistema de servidores de distribución que permite que el espacio de nombre esté disponible.
- Un sistema de cliente que permite "resolver" nombres de dominio, es decir, interrogar a los servidores para encontrar la dirección **IP** que corresponde a un nombre.

### Espacio de nombre:

La estructura del sistema **DNS** se basa en una estructura de arbórea en donde se definen los dominios de nivel superior (llamados **TLD**, Dominios de Nivel Superior); esta estructura está conectada a un nodo raíz representado por un punto.



Cada servidor de nombre de dominio está especificado en el servidor de nombre de dominio en el nivel superior inmediato, lo que significa que la autoridad sobre los dominios puede delegarse implícitamente. El sistema de nombre es una arquitectura distribuida, en donde cada entidad es responsable de la administración de su nombre de dominio. Por lo tanto, no existe organización alguna que sea responsable de la administración de todos los nombres de dominio.

Los servidores relacionados con los dominios de nivel superior (**TLD**) se llaman "servidores de dominio de nivel superior". Son 13, están distribuidos por todo el mundo y sus nombres van desde "a.root-servers.net" hasta "m.root-servers.net".

### **Resolución de nombres de dominio:**

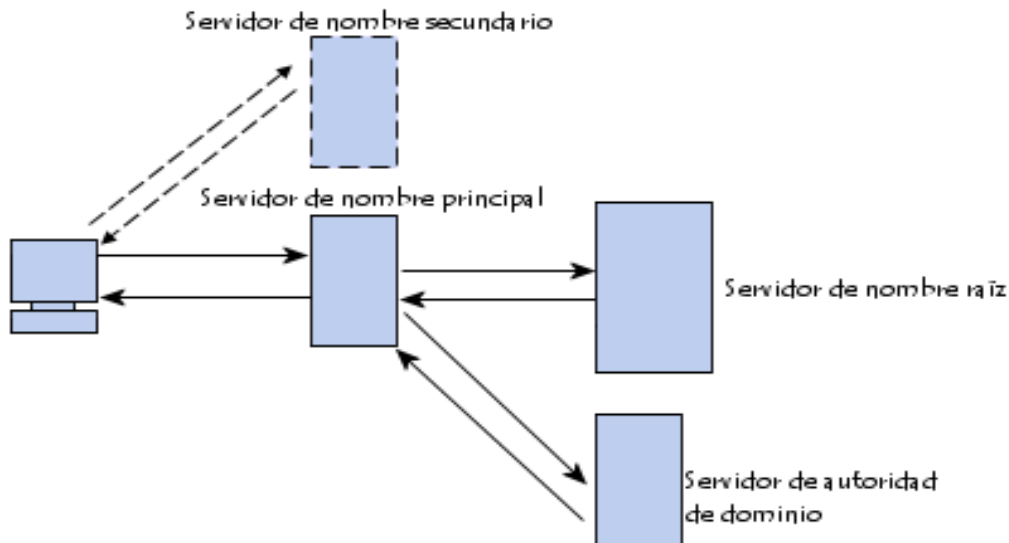
El mecanismo que consiste en encontrar la dirección IP relacionada al nombre de un ordenador se conoce como "resolución del nombre de dominio". La aplicación que permite realizar esta operación (por lo general, integrada en el sistema operativo se llama "resolución".

Cuando una aplicación desea conectarse con un host conocido a través de su nombre de dominio (por ejemplo, "es.kioskea.net"), ésta interroga al servidor de nombre de dominio definido en la configuración de su red. De hecho, todos los equipos conectados a la red tienen en su configuración las direcciones **IP** de ambos servidores de nombre de dominio del proveedor de servicios.

Entonces se envía una solicitud al primer servidor de nombre de dominio (llamado el "servidor de nombre de dominio principal"). Si este servidor de nombre de dominio tiene el registro en su caché, lo envía a la aplicación; de lo contrario, interroga a un servidor de nivel superior (en nuestro caso un servidor relacionado con el **TLD** ".net").

El servidor de nombre de nivel superior envía una lista de servidores de nombres de dominio con autoridad sobre el dominio (en este caso, las direcciones **IP** de los servidores de nombres de dominio principal y secundario para [comofunciona.net](http://comofunciona.net)).

Entonces el servidor de nombres de dominio principal con autoridad sobre el dominio será interrogado y devolverá el registro correspondiente al dominio del servidor (en nuestro caso [www](http://www)).



### Tipos de registros:

Un **DNS** es una base de datos distribuida que contiene registros que se conocen como RR (Registros de Recursos), relacionados con nombres de dominio. La siguiente información sólo es útil para las personas responsables de la administración de un dominio, dado que el funcionamiento de los servidores de nombre de dominio es completamente transparente para los usuarios.

Ya que el sistema de memoria caché permite que el sistema **DNS** sea distribuido, los registros para cada dominio tienen una duración de vida que se conoce como **TTL** (Tiempo de vida). Esto permite que los servidores intermediarios conozcan la fecha de caducidad de la información y por lo tanto que sepan si es necesario verificarla o no.

Por lo general, un registro de **DNS** contiene la siguiente información:

Nombre de dominio (**FQDN**) TTL Tipo Clase RData

es.kioskea.net 3600 A IN 163.5.255.85

- Nombre de dominio: El nombre de dominio debe ser un nombre **FQDN**, es decir, debe terminar con un punto. En caso de que falte el punto, el nombre de dominio es relativo, es decir, el nombre de dominio principal incluirá un sufijo en el dominio introducido;
- Tipo: Un valor sobre 16 bits que define el tipo de recurso descrito por el registro. El tipo de recurso puede ser uno de los siguientes:

**A:** este es un tipo de base que hace coincidir el nombre canónico con la dirección **IP**. Además, pueden existir varios registros **A** relacionados con diferentes equipos de la red (servidores).

**CNAME** (Nombre Canónico): Permite definir un alias para el nombre canónico. Es particularmente útil para suministrar nombres alternativos relacionados con diferentes servicios en el mismo equipo.

**HINFO:** Este es un campo solamente descriptivo que permite la descripción en particular del hardware del ordenador (CPU) y del sistema operativo (OS). Generalmente se recomienda no completarlo para evitar suministrar información que pueda ser útil a piratas informáticos.

**MX** (Mail Exchange): es el servidor de correo electrónico. Cuando un usuario envía un correo electrónico a una dirección (user@domain), el servidor de correo saliente interroga al servidor de nombre de dominio con autoridad sobre el dominio para obtener el registro **MX**. Pueden existir varios registros **MX** por dominio, para así suministrar una repetición en caso de fallas en el servidor principal de correo electrónico. De este modo, el registro **MX** permite definir una prioridad con un valor entre 0 y 65,535:

- **NS:** es el servidor de nombres de dominio con autoridad sobre el dominio.
- **PTR:** es un puntero hacia otra parte del espacio de nombres del dominio.
- **SOA** (Start Of Authority (Inicio de autoridad)): el campo **SOA** permite la descripción del servidor de nombre de dominio con autoridad en la zona, así como la dirección de correo electrónico del contacto técnico (en donde el carácter "@" es reemplazado por un punto).
- **Clase:** la clase puede ser **IN** (relacionada a protocolos de Internet, y por lo tanto, éste es el sistema que utilizaremos en nuestro caso), o **CH** (para el sistema caótico);
- **RDATA:** estos son los datos relacionados con el registro.

Aquí se encuentra la información esperada según el tipo de registro:

- **A:** la dirección **IP** de 32 bits;
- **CNAME:** el nombre de dominio;
- **MX:** la prioridad de 16 bits, seguida del nombre del ordenador;
- **NS:** el nombre del ordenador; **PTR:** el nombre de dominio
- **PTR:** el nombre de dominio;
- **SOA:** varios campos.

### **Dominios de nivel superior:**

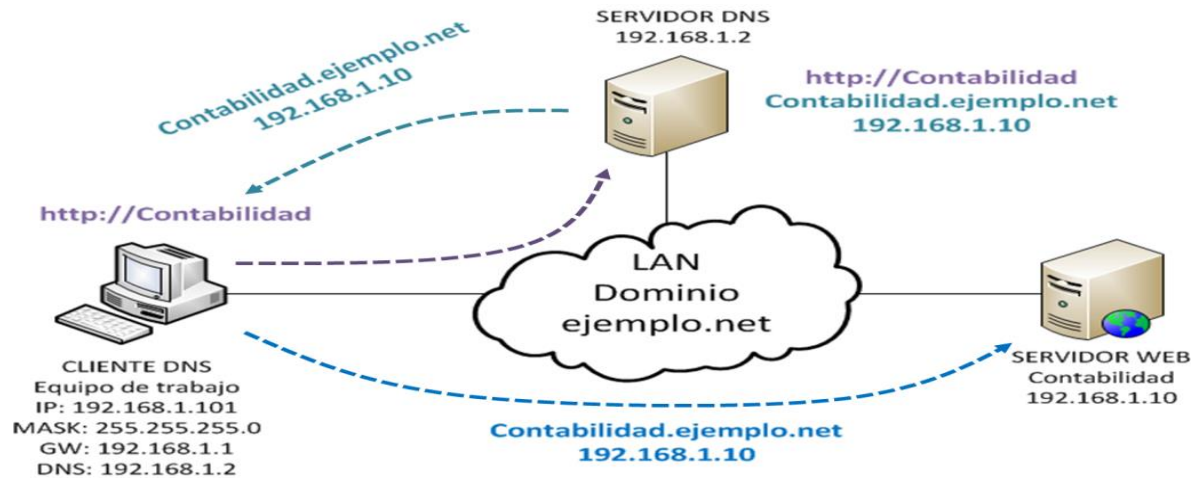
Existen dos categorías de TLD (Dominios de Nivel Superior):

- Los dominios que se conocen como "genéricos", llamados gTLD (TLD genérico). Los gTLD son nombres de dominio de nivel superior genéricos que ofrecen una clasificación de acuerdo con el sector de la actividad. Entonces cada gTLD tiene sus propias reglas de acceso:
  - gTLD historial:
    - .arpa relacionado con equipos pertenecientes a la red original;
    - .com inicialmente relacionado con empresas con fines comerciales. Sin embargo, este TLD se convirtió en el "TLD predeterminado" y hasta personas reales pueden adquirir dominios con esta extensión.
    - .edu relacionado con las organizaciones educativas;
    - .gov relacionado con las organizaciones gubernamentales;
    - .int relacionado con las organizaciones internacionales;
    - .mil relacionado con las organizaciones militares;
    - .net inicialmente relacionado con las organizaciones que administran redes. Con el transcurso de los años este TLD se ha convertido en un TLD común, y hasta personas reales pueden adquirir dominios con esta extensión.
    - .org está normalmente relacionado con organizaciones sin fines de lucro.
  - nuevos gTLD presentado en noviembre de 2000 por ICANN:
    - .aero relacionado con la industria aeronáutica;
    - .biz (negocios) relacionado con empresas comerciales;
    - .museum relacionada con los museos;
    - .name relacionada con el nombre de personas reales o imaginarias;
    - .info relacionado con organizaciones que manejan información;
    - .coop relacionado con cooperativas;
    - .pro relacionado con profesiones liberales.
  - gTLD especial:
    - .arpa relacionado con las infraestructuras para la administración de redes. El arpa gTLD también sirve para la resolución inversa de equipos en red y permite hallar el nombre relacionado con una dirección IP.
- Los dominios que se conocen como "nacionales", se llaman ccTLD (código de país TLD). El ccTLD está relacionado con los diferentes países y sus nombres se refieren a las abreviaturas del nombre del país definidas en la norma ISO 3166.

A continuación, algunos ejemplos de la lista de ccTLD.

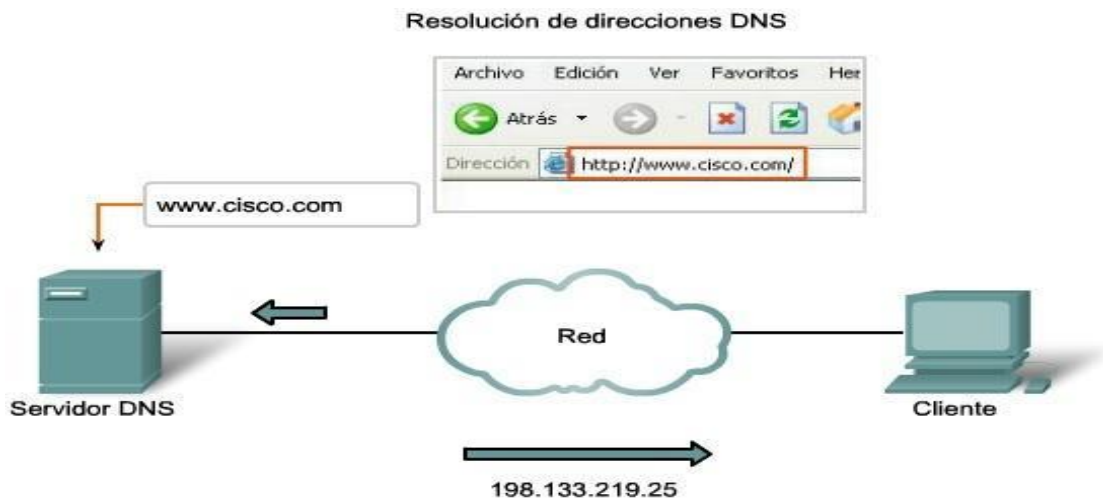
CÓDIGO: AR (Argentina), CO (Colombia), ES (España), HK (Hong Kong), NZ (Nueva Zelanda), UK (Reino Unido), ZA (Sudáfrica).

Si un equipo quiere comunicarse con otro llamado “CONTABILIDAD”, la comunicación de red, se realizaría mediante IP, pero antes deberá averiguar cuál es la misma, utilizando la resolución de nombres.



Teniendo un servidor DNS, esa consulta la haría él mismo, buscaría en su zona si está ese equipo relacionado con una IP, y al encontrarlo, enviaría esa información al equipo que realizó la consulta.

En INTERNET, es constante la consulta con servidores DNS (ROOT HINTS), los cuales contienen la información necesaria para encontrar un dominio.



El número se envía de regreso al cliente para su utilización en la realización de solicitudes del servidor.

## **RECORDAR:**

La información proporcionada por un servidor DNS se presenta en diferentes categorías llamadas registros.

**A:** son los registros principales, relaciona un nombre con una dirección IP

**PTR:** el inverso de A, relaciona una dirección IP con un nombre

**NS:** identifica a los servidores DNS del dominio consultado

**MX:** identifica a los servidores de correo electrónico correspondientes del dominio consultado, son utilizados por los servidores SMTP que posean correos electrónicos destinados a usuarios dentro de nuestro dominio.

### **Ejercicio Número 3 Unidad 3**



Utilizar y probar el comando “**nslookup**”, usar como guía el **help** del mismo comando.

Buscar 3 direcciones **IP** y resolverlas a través del mismo comando.

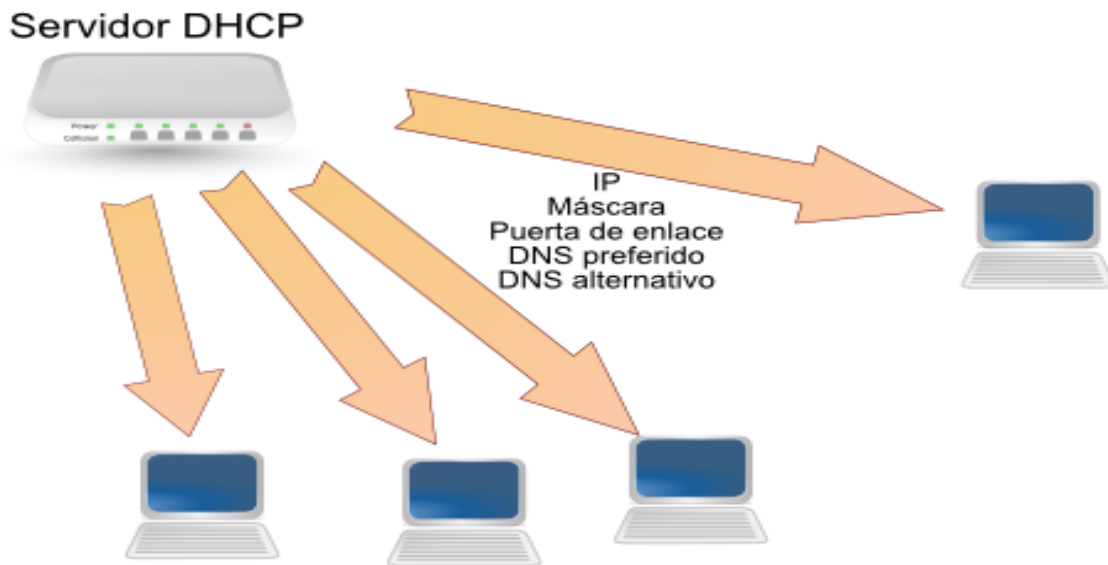
**Para los que no conocen este comando, tienen un Link TIP:**

<https://norfipc.com/redes/como-usar-comando-nslookup-windows.html>

Recordar que es un comando propio del sistema operativo, hay cientos de comandos y puede resultar tedioso buscar información por muchos lados, por eso en esta práctica intentamos estimular al alumno a realizar estos ejercicios, que son parte del conocimiento básico que uno debe tener y exponemos links de ayuda recomendados.

## DHCP (Dynamic Host Configuration Protocol)

Se encarga de proveer las configuraciones necesarias de conectividad a los dispositivos (compatibles con este servicio) que se conectan a la red de una manera automática, simple y rápida.



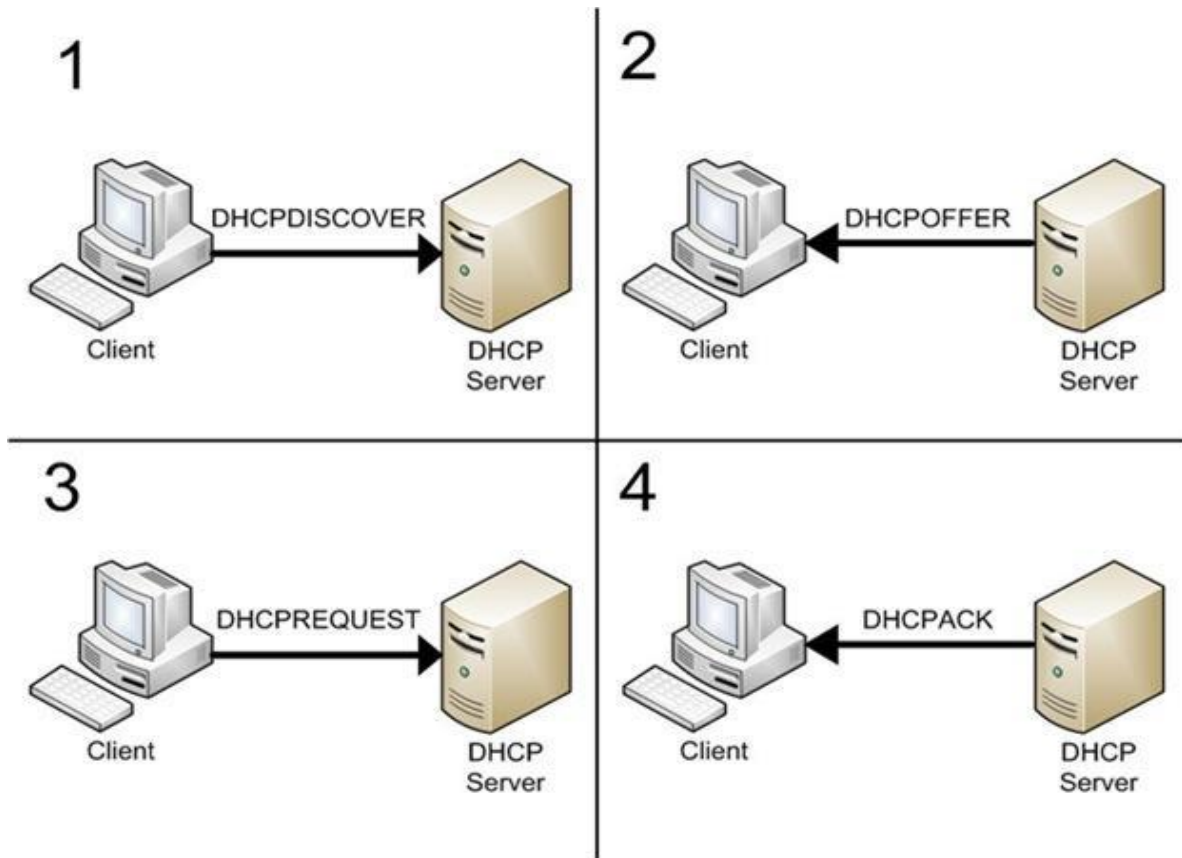
Gracias a este servicio, no es necesario configurar un dispositivo en forma manual, el solo hecho de conectarlo a la red, tomaría un direccionamiento automático de acuerdo a como lo configuramos.

Los pasos serían los siguientes:

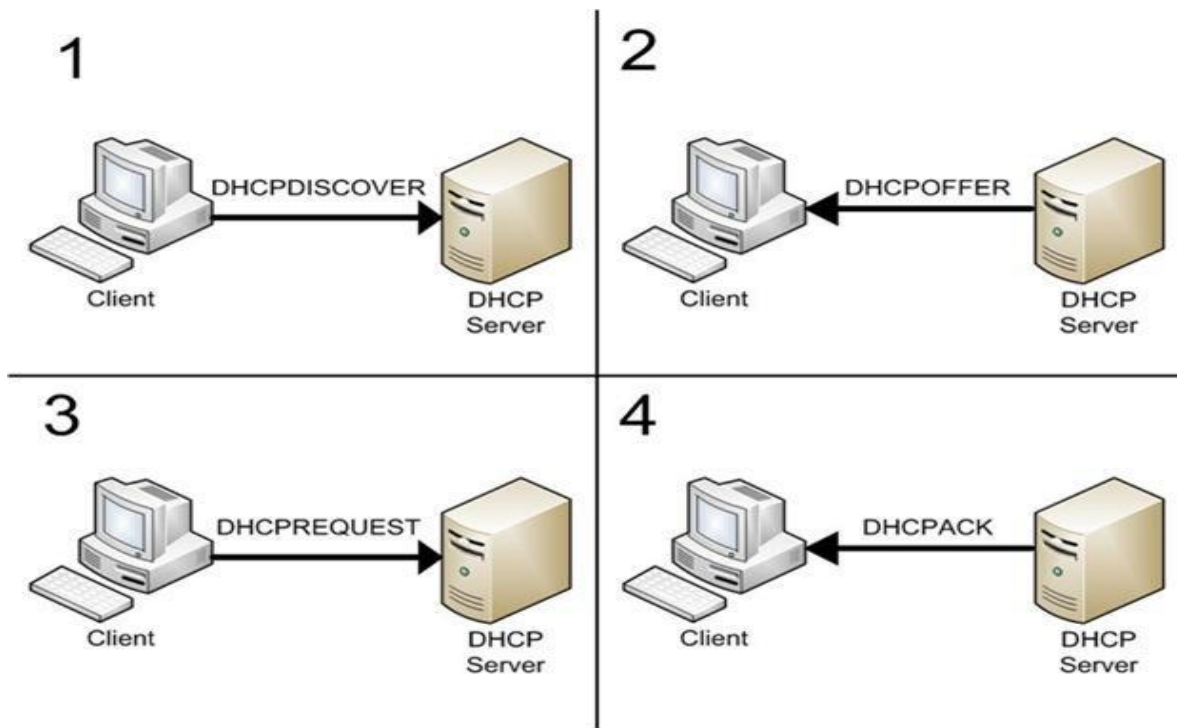
- Se conecta un dispositivo en una boca de red o por WIFI.
- El dispositivo enviará paquetes de broadcast llamado **DHCPDISCOVER** buscando la existencia de un servidor **DHCP**.
- El servidor de **DHCP**, al recibir esa solicitud, reservara de su address pool, una dirección asignada a la **MAC** del dispositivo solicitante, enviándole una respuesta con un paquete unicast llamado **DHCPOFFER**, indicando un resumen del segmento de red.
- Este paquete será recibido únicamente por el dispositivo solicitante.

Cuando el dispositivo lo reciba, enviará un **DHCPREQUEST**, que simboliza el pedido oficial de obtención de su dirección IP y la conexión a la red.

El servidor lo recibe, asigna la IP reservada anteriormente, y envía un **DHCPACK**, notificando la aceptación del servidor, junto con la lista completa de opciones de configuración asignadas al cliente, más un tiempo de la duración de la reserva (**lease**).



### Ejercicio Número 4 Unidad 3



A partir de la gráfica anterior, explicar el proceso de DHCP (con sus palabras o sea que comprendieron) en el dibujo anterior, y especificar cómo sería el direccionamiento IP que ofrecería a los dispositivos (la máscara es 255.255.255.0 o podría ser la 255.255.0.0)

AYUDA: hay un servicio que todavía no se enseñó que permitiría el uso de dos segmentos de red diferentes a través de un SW, ¿cuál es?

# Laboratorio teórico: Potenciales ataques

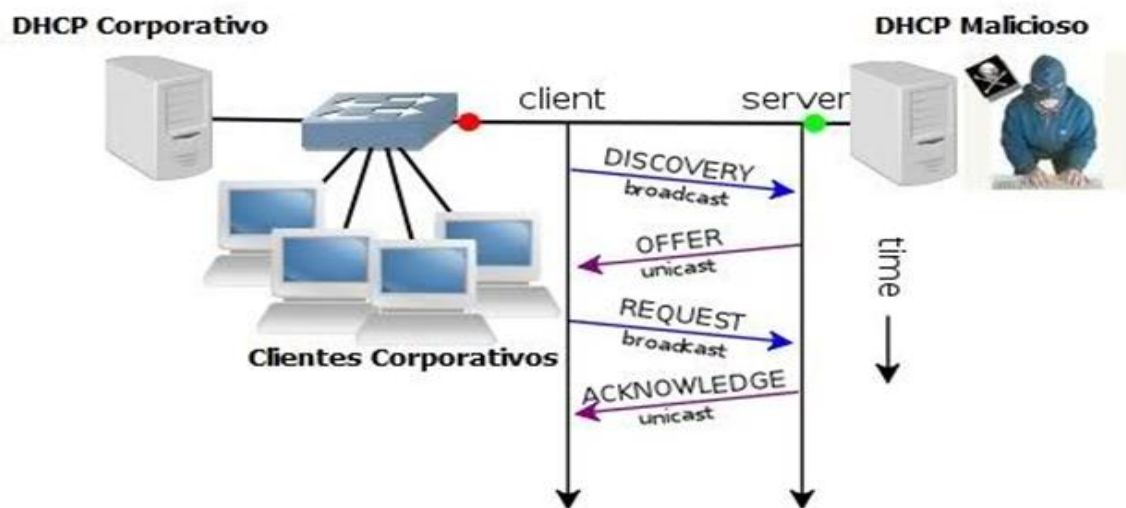


Estos son los nombres de algunos ataques más conocidos (a **DHCP**):

## **DHCP STARVATION**

Es un ataque que consiste en inundar con peticiones **DHCP REQUEST** al servidor **DHCP**, con direcciones **MAC** falseadas y con el objetivo de agotar su espacio de direcciones asignables. El objetivo es que el servidor **DHCP** no sea capaz de responder a otros clientes.

## **DHCP SPOOFING**



Consiste en suplantar al servidor de **DHCP** de una red y modificar los parámetros de red que reciben los equipos conectados al renovar o solicitar una nueva **IP**.

### **DHCP ROGUE SERVER**

Un **DHCP** rogue server es un servidor que se encuentra en la red fuera del control del administrador de la misma para hacer ataques de tipo **MITM** modificando los parámetros de red que reciben los equipos de la red. Tiene el inconveniente de que no puede asegurarse que reciba la configuración los equipos del servidor atacante al existir un atacante legítimo en la red.

### **DHCP ACK INJECTION ATTACK**

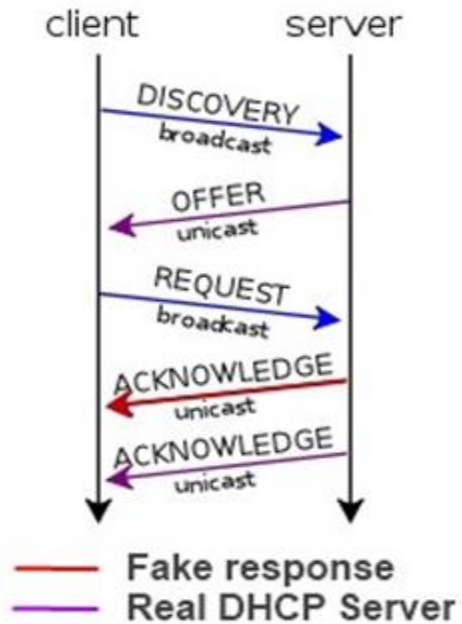
Tipo de ataque que mejora la utilización de un **DHCP** rogue server para hacer **DHCP** spoofing ya que se asegura de que los equipos reciban la configuración del servidor atacante.

Dado que toda la comunicación **DHCP** se realiza enviando los paquetes a la dirección **MAC** de broadcast FF:FF:FF:FF:FF:FF todos los clientes reciben los paquetes **DHCP**. Así que existe la posibilidad de que un atacante monitorice los intercambios **DHCP** y en un determinado punto de la comunicación envíe un paquete especialmente formado para modificar su comportamiento.

Uno de los puntos donde nos interesaría intervenir es cuando el servidor reconoce con un **DHCP ACK** la configuración del cliente. Primero se tiene que escuchar toda la comunicación poniendo atención en el paquete **REQUEST** donde el cliente solicita la **IP Gateway** de aquellos datos que anteriormente le ha ofrecido el servidor **DHCP**.

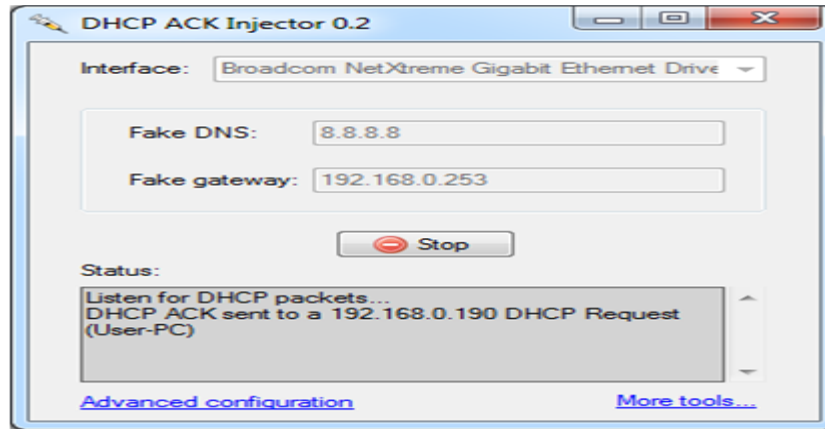
Una vez recibido el **REQUEST** el atacante responde con un **ACK** como lo haría el servidor **DHCP** real pero estableciendo la configuración de red modificada.

En el siguiente esquema se muestra el ataque:



Existe una herramienta denominada **DHCP ACK Injector** que es capaz de realizar este tipo de ataques. Entre sus parámetros configurables está:

- El servidor de que se le da al cliente
- La puerta de enlace que se le suministra al cliente.
- La dirección **MAC** del servidor **DHCP**
- La dirección **IP** del servidor



## DHCP EXHAUSTION ATTACK

Ataque consistente en realizar peticiones **DHCP REQUEST** al servidor hasta que deja de recibir respuesta del servidor porque este ha agotado su pool de direcciones disponibles. Es un ataque de tipo denegación de servicio, ya que cualquier otro equipo que haga petición de concesión o renovación de **DHCP** no va a obtener respuesta del servidor. La diferencia con STARVATION, está en que el envío es con MAC inexistentes contra MAC reales.



De acuerdo a lo aprendido en las últimas 3 unidades, hacer un entregable, explicando cuáles podrían ser potenciales formas de mitigar los ataques en cada servicio o protocolo, por ejemplo, un ataque a un servidor DHCP.

Especificar diciendo nombre del ataque y servicio o protocolo atacado.

Al menos seleccionar 1 ataque de todos lo que vimos, relacionados con lo aprendido.

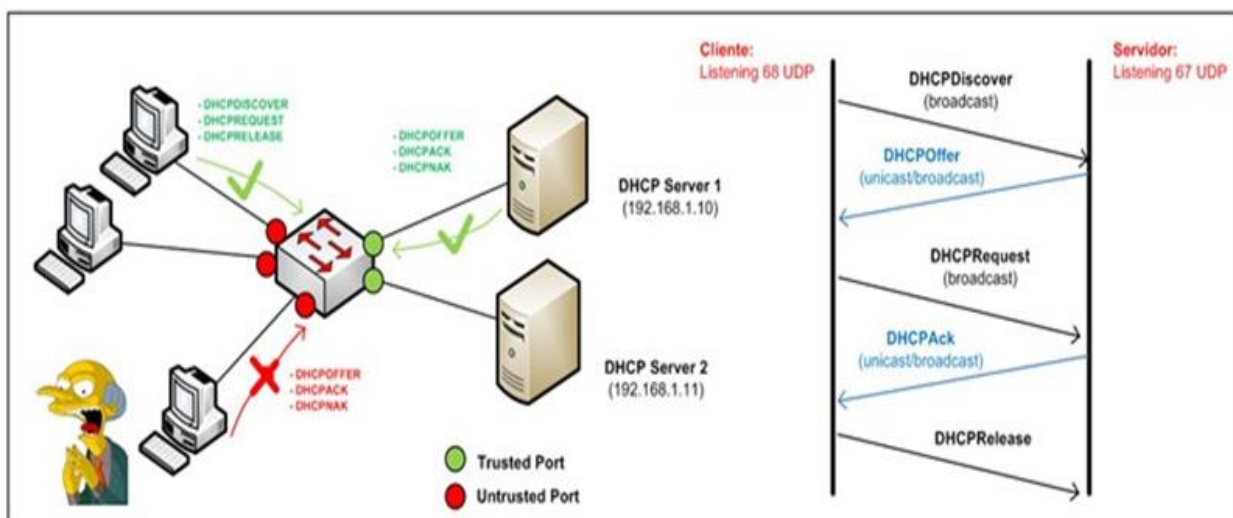
A continuación, se brinda un aporte, pero la idea es que lo hagan con sus palabras:

**VACL (Vlan Access List):** proporcionan control de acceso a todos los paquetes que se incluyen dentro de la **VLAN** permite filtrar paquetes a determinados puertos.

Habría que bloquear el tráfico proveniente del puerto 67 para aquellos puertos del switch destinados al usuario final. El problema de esta contramedida es que podría evadirse fácilmente si se falsifica la **MAC** e **IP** de los paquetes (y que en el caso de **DHCP Ack Injector** es posible)

**DHCP snooping:** provee una protección más fiable.

La idea de esta funcionalidad es diferenciar entre dos tipos de puertos en un entorno conmutado: por un lado, puertos confiables (trusted port) y, por otro, puertos no confiables (untrusted host).



Los primeros no tendrán restricciones de cara al tipo de mensajes DHCP que puedan recibir, puesto que serán aquellos conectados a un entorno controlado (en este caso a los servidores DHCP). Sin embargo, los segundos únicamente podrán enviar aquellos paquetes que en condiciones normales un cliente necesita enviar para conseguir su configuración DHCP (**DHCPDiscover**, **DHCPRequest**, **DHCPRelease**).

Los untrusted port por tanto serán configurados en aquellos puertos conectados a los usuarios finales y en el caso de que dicho puerto reciba un paquete suplantado **DHCPoffer**, un **DHCPack**, o **DHCPNack** (este es el caso de DHCP Ack Injector), serán bloqueados.

## **Cómo presentar los ejercicios de la unidad**

Hay dos tipos de ejercicios, los de la unidad (QUE NO SON OBLIGATORIOS) y los que se exponen como obligatorios (que son los finales de cada módulo)

La idea está en que cada uno pueda desarrollar todos los ejercicios y expresarlos en un archivo .doc o .pdf y lo suba al correspondiente foro que estará habilitado.

En el mismo, el formato del archivo será apellido\_UnidadX.doc (donde apellido será el de cada uno y la “X” el número de la unidad de los ejercicios)

Esto significa que en un solo archivo deberían estar todos los ejercicios de la unidad correspondiente, así centralizamos lo de cada uno.

Es muy IMPORTANTE que realicen todos los ejercicios (aun no siendo obligatorios) ya que, al ser un curso a distancia, es una herramienta para saber si hubo una buena comprensión de la unidad.

Luego los mismos serán revisados por el instructor, por eso es importante que lo hagan pronto, para que no se les sume ejercicios de otras unidades.

Pueden ser revisados por todos los demás alumnos e instructor para dar puntos de vista, ayuda o guía.

### **Los ejercicios de esta unidad no llevan calificación**

Los únicos ejercicios que tienen puntuación son los finales, que se realizan cada 4 unidades, pero más adelante se hablará de esto.



## Bibliografía utilizada y sugerida

Harrington, J.(2006) Manual práctico de seguridad de redes. Editorial Anaya Multimedia. México

Hush J.(2020) Redes Informáticas Para Principiantes: La Guía Completa de la Tecnología Inalámbrica, La Seguridad de Redes, Arquitectura de Las Computadoras Y Los Sistemas de Comunicación. Editorial Charlie Creative Lab. España

Dorsel, R.(2020) Hacking for Beginners: Mastery Guide to Learn and Practice the Basics of Computer and Cyber Security. Editorial Charlie Creative Lab. EEUU

Trew, P.(2020) Kali Linux Hacking: A Complete Guide to Learn the Fundamentals of Hacking, Cyber Security, and Penetration Testing. Editorial Charlie Creative Lab. EEUU

Knox, J.(2020) Computer Hacking. Editorial Charlie Creative Lab. EEUU

## Link complementarios:

<https://es.slideshare.net/slideshow/tipos-de-ataques-y-vulnerabilidades-en-una-red/10551321>

¿Cómo funciona ARP?:

<https://www.youtube.com/watch?v=DoQcznhxbhw>

En caso de que los links que se exponen no funcionen, por favor avisar al instructor (es normal que un sitio pueda cambiar su URL, dominio o variables, lo cual como la unidad se prepara a principio de año podría suceder que se haya modificado)



Módulo 1:

## **Diseño de redes seguras**

Unidad 4:

## **Redes informáticas – Seguridad Aplicada**



## Presentación

En esta cuarta y última unidad del módulo, nos introducimos en la comprensión de la temática correspondiente a redes seguras, servicios necesarios y procesos a aplicar.

Uso correcto de las Access-list, basándonos en Sistemas IOS de CISCO.

Exposición del primer final obligatorio del módulo.



## Objetivos

Que los participantes logren...

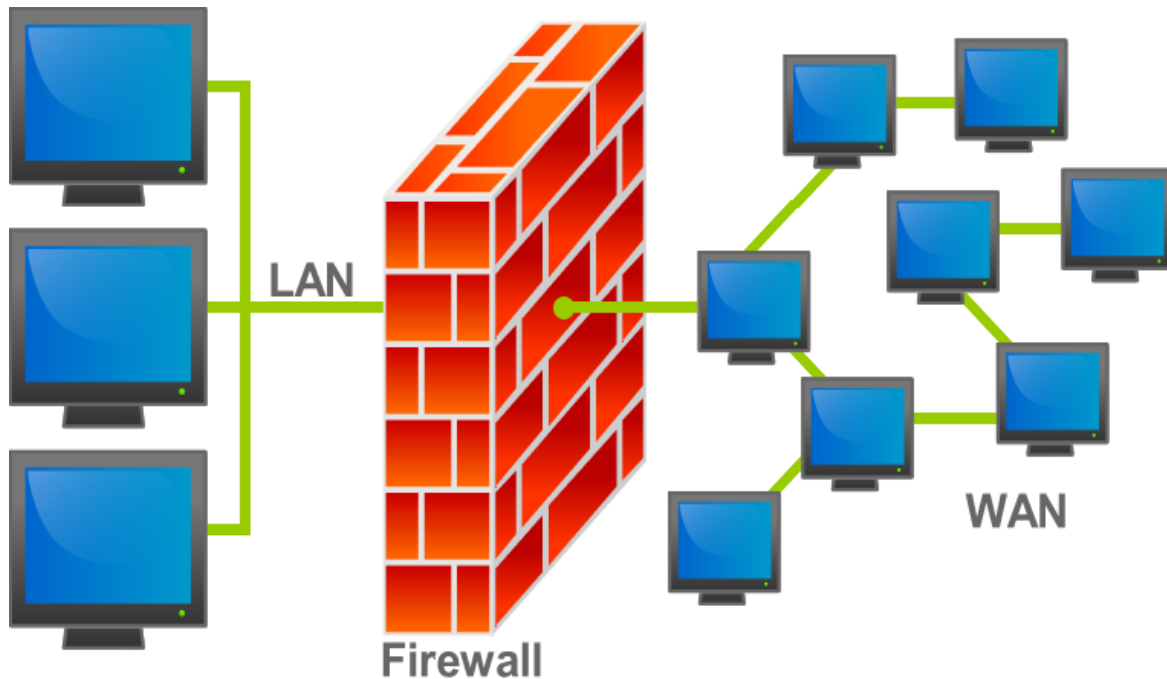
- Conocer los conceptos generales de las redes de comunicación, los protocolos, los diferentes dispositivos y sus funciones.
- Aprender a planear, diseñar, estructurar e implementar una infraestructura de red informática de manera segura, protegiéndola de potenciales amenazas.



## Bloques temáticos

1. Dispositivos de seguridad (funcionalidades y modo de uso).
2. Estructuración de una red segura.
3. Armado de una red segura.
4. Ejercicio Final de módulo.

## Dispositivos de Seguridad



Anteriormente hablamos de varios dispositivos, entre ellos, el firewall, ahora veremos las maneras de cómo usarlo y que es lo que nos ofrece para protegernos de ataques o de intrusos.

Un firewall, tiene como condición principal (siempre y cuando esté bien configurado) bloquear todo acceso no autorizado.

Primer consejo, antes de ponerlo en la red, sería bueno saber **que proteger, como proteger y donde proteger.**

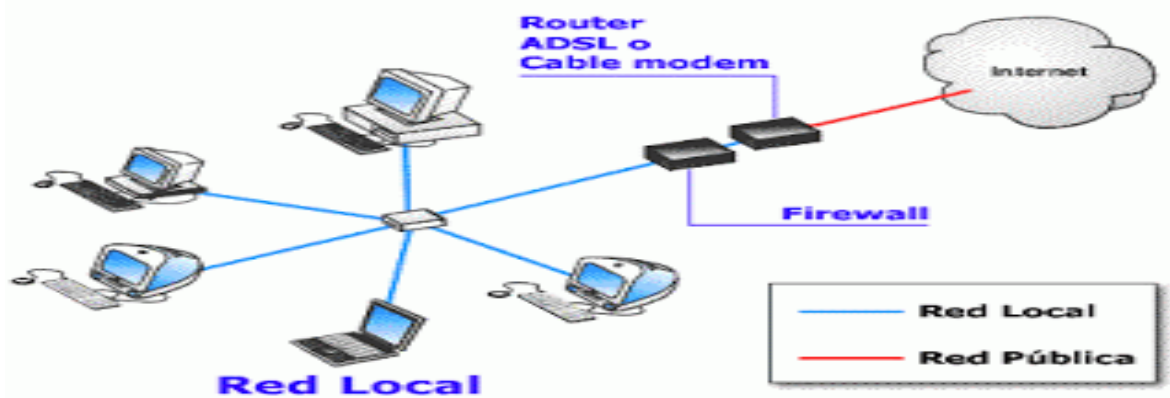
Nos encontraremos dentro de sus servicios con **ACLs** (listas de acceso), **VPN** (virtual private network), **NAT** (network address translation).

Cuando hablamos de saber **que proteger**, es poner en importancia y determinar cuáles son los activos más importantes de la red.

Pueden ser equipos, servicios o hasta un determinado tipo de tráfico (cifrado de datos por ejemplo).

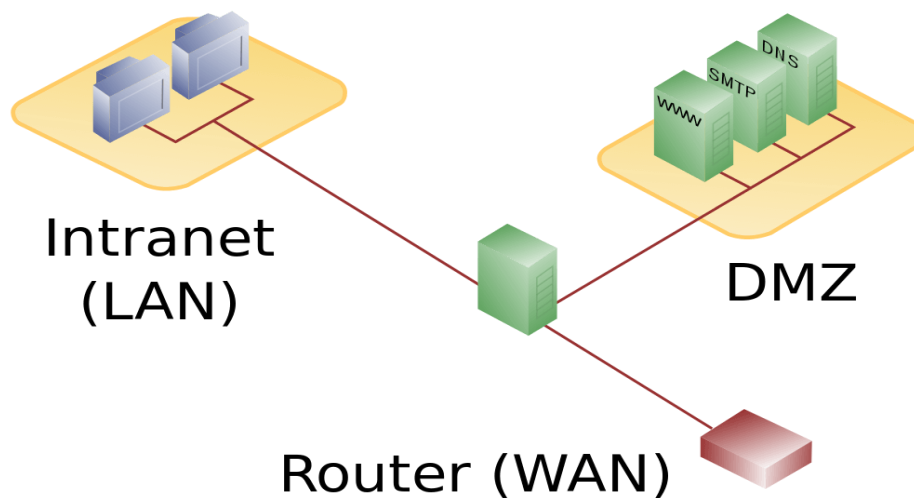
No es lo mismo, proteger un equipo que se usa para repositorio que un servidor principal web de la empresa.

El **que proteger**, lo determinaremos haciendo un análisis de riesgo de la red, donde sabremos el nivel de importancia.



Un ejemplo muy común de donde poner un firewall en la red, en este caso, el que proteger, sería toda la red local.

Otro ejemplo, es que interceda entre los servicios que se necesitan publicar a Internet y la red LAN.

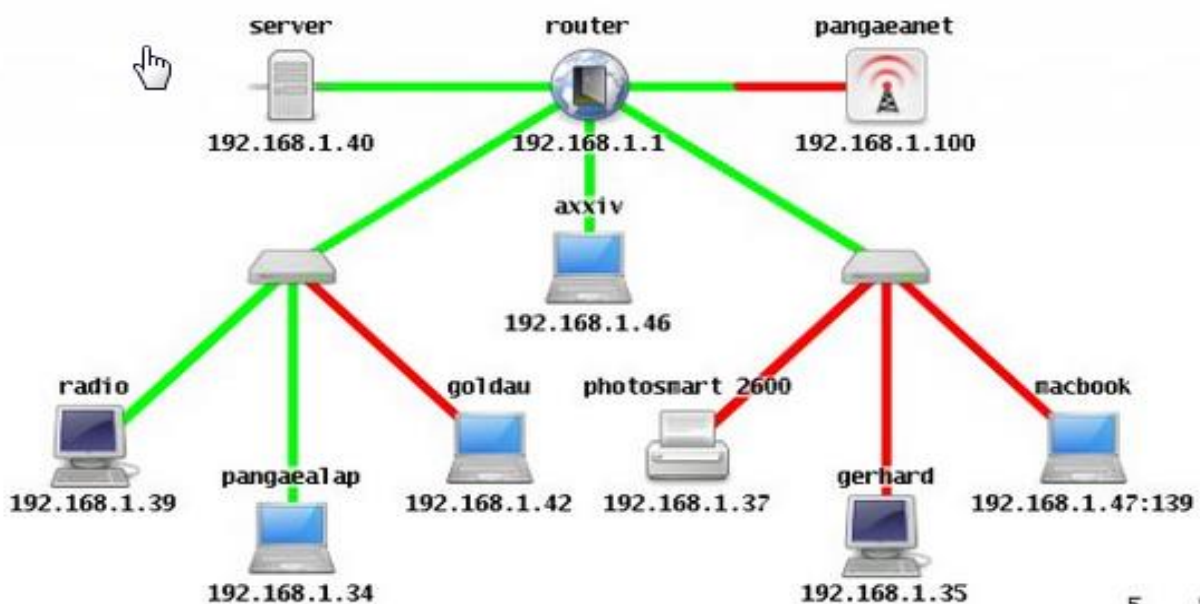


## Ejercicio Número 1 Unidad 4



A continuación se expondrá un gráfico, donde el alumno/a será el que tome la decisión de dónde ubicar un Firewall.

Es de libre interpretación y no lleva corrección, todos tienen que poner su punto de vista y defender su postura.



Datos a tener en cuenta: sabiendo que los enlaces rojos, tienen prioridad de salida a Internet por la antena, y los verdes prioridad de acceso al servidor más importante de la topología.

El instructor analizará este ejercicio en la clase virtual, exponiendo distintos puntos de vista.

**El cómo proteger**, sería teniendo en cuenta parte de los servicios que nos ofrezca el firewall (ACLs, NAT, VPN) y el buen uso y configuración de los mismos.

## ¿Qué es una ACL?

Es una forma de determinar los permisos de acceso apropiados a un determinado objeto, dependiendo de ciertos criterios del proceso que hace el pedido.

Estas operaciones podrían incluir lectura, escritura y ejecución sobre un destino.

Los criterios serían: el origen del tráfico; el destino del tráfico; el protocolo usado.

Funciona a través del firewall o router que analizan cada paquete, comparándolo con la **ACL** correspondiente y compara la **ACL** línea por línea.

Si encuentra una coincidencia, toma la acción correspondiente (**PERMIT** o **DENY**), y ya no revisa los restantes renglones.

Es por eso que hay que listar los comandos desde los casos más específicos, hasta los más generales.

Recordar:

- ⇒ Esencialmente son listas de condiciones para poder acceder a una red o dispositivo.
- ⇒ Son una herramienta muy poderosa para controlar el acceso en ambos sentidos: tanto desde como hacia la red.
- ⇒ Pueden filtrar tráfico no deseado, y son utilizadas para implementar políticas de seguridad.
- ⇒ Al aplicar una lista de acceso, se obliga al router a analizar cada paquete que atraviesa la interfase en una dirección específica, reduciendo de esta manera la performance del dispositivo.
- ⇒ Cada paquete es comparado con cada línea de la lista de acceso en orden secuencial según han sido ingresadas.
- ⇒ La comparación se realiza hasta que se encuentra una coincidencia.

⇒ NO OLVIDAR – El final implícito de toda lista de acceso es una denegación de todo tráfico: deny all

**¡Las excepciones tienen que estar antes de la regla general!**

¿Y CUAL ES LA REGLA GENERAL?

**Si no encuentra una coincidencia en ninguno de los renglones, rechaza automáticamente el tráfico**

```
RTA#config t
RTA(config)#access-list 1 permit 192.168.1.0 0.0.0.255
RTA(config)#access-list 1 permit 192.168.3.0 0.0.0.255
RTA(config)#access-list 1 permit 192.168.5.0 0.0.0.255
!---Implied "Deny Any"
```

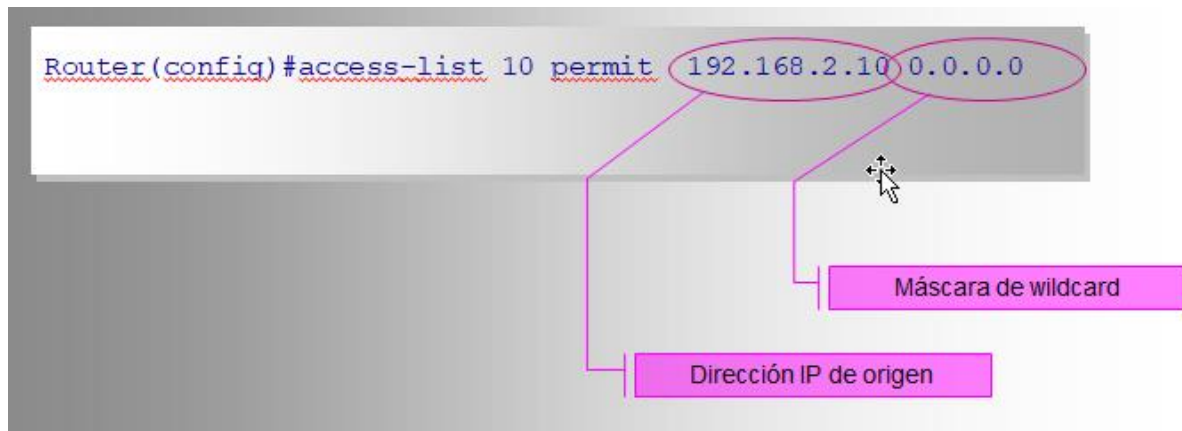
**Consideren que hay un "deny any" implícito, al final de cada ACL**

Existen muchas maneras de crear un **ACL**, dependemos de qué tipo de tecnología se use, escribiéndola o por intermedio de opciones en la aplicación que se esté corriendo.

En CISCO, por ejemplo, hay 2 tipos de **ACL más conocidas**, las **extendidas** y las **estándar**, y se pueden configurar tanto en routers como firewalls.

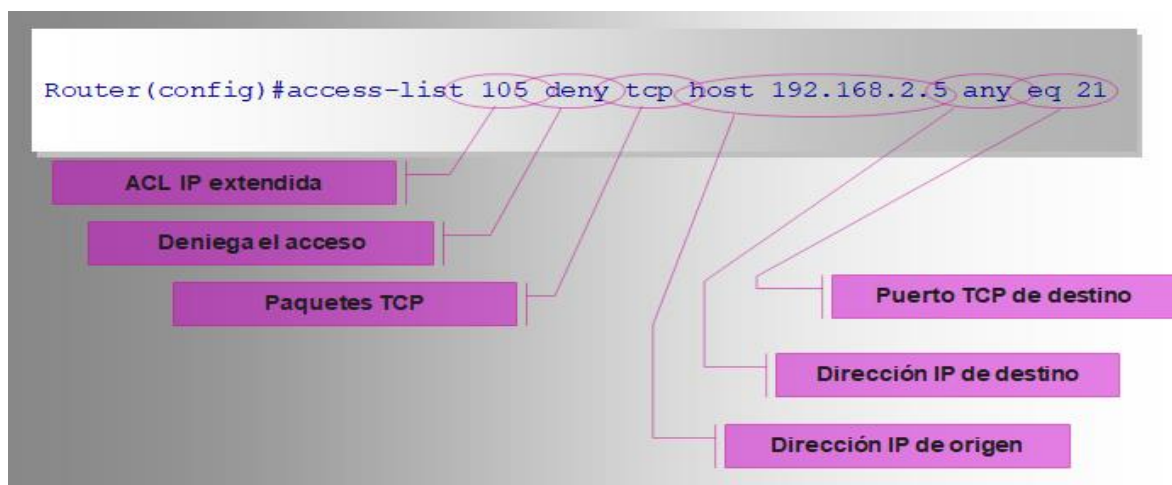
⇒ **Listas de Acceso Estándar**

- **IP** – Filtran paquetes IP considerando solamente la dirección IP de origen.



#### ⇒ Listas de Acceso Extendidas

- **IP** – Filtran paquetes IP considerando tanto la dirección de origen como la de destino, y los números de puerto del encabezado de capa de transporte.



#### TIPS:

- ⇒ Solo se puede asignar una lista de acceso por interface.
- ⇒ Organice su lista de acceso de modo que los criterios más específicos estén al inicio.
- ⇒ Si en algún momento se agrega una nueva línea a la lista, esta se ubicará al final de la misma.
- ⇒ No se puede remover una línea de una lista de acceso.

- ⇒ Al menos que su lista termine con un comando permit, todo los paquetes que no coincidan con alguno de los criterios serán descartados.
- ⇒ Toda lista de acceso debe tener al menos un comando permit.
- ⇒ Primero cree la lista de acceso, y luego aplíquela a la interfaz.
- ⇒ Las listas de acceso están diseñadas para filtrar el tráfico que atraviesa el router. No filtran el tráfico originado en el router.
- ⇒ Ubique las listas de acceso estándar lo más cerca posible del destino.
- ⇒ Ubique las listas de acceso extendidas lo más cerca posible del origen.

### **Ejemplo:**

Quiero permitir únicamente el host (10.10.10.20)

La sintaxis podría ser la siguiente:

**Access-list 1 permit IP host 10.10.10.20**

Obsérvese que de cumplirse esta ACL, los demás equipos tendrán el **deny** implícito.

¿Por qué?

Se expone que únicamente esa IP tendrá permiso, y al no poner más direcciones **IP**, por ende niega todo tráfico.

### **Otro ejemplo:**

Quiero permitir el acceso de la red (20.20.20.0) hacia la red (30.30.30.0) pero que el equipo con **IP: 20.20.20.5** no lo tenga

La sintaxis podría ser la siguiente:

**Access-list 101 deny IP host 20.20.20.5 30.30.30.0 0.0.0.255**

**Access-list 101 permit IP 20.20.20.0 0.0.0.255 30.30.30.0 0.0.0.255**

¿Por qué?

Primero negamos la específica, que sería la **IP 20.20.20.5** y luego le exponemos lo que si le permitimos.

Cualquier otra dirección **IP** que no sea de las expuestas, **NO** estaría permitida.

Hay que prestar mucha atención, porque el solo hecho de no exponer una/las direcciones IP, podría resultar incómodo encontrar por qué un equipo tiene tráfico y el otro no, a menos que uno sepa que la culpa la tiene la ACL.

Lo más utilizado, es poner primero lo más específico y luego lo genérico (o sea lo que sabemos que se tiene que negar por defecto).

### Otro ejemplo:

Tengo dos redes, la red **10.10.10.0** y la red **20.20.20.0**.

La red **10.10.10.0** NO tiene permitido salir a internet (**200.200.200.200**) y la red **20.20.20.0** SI.

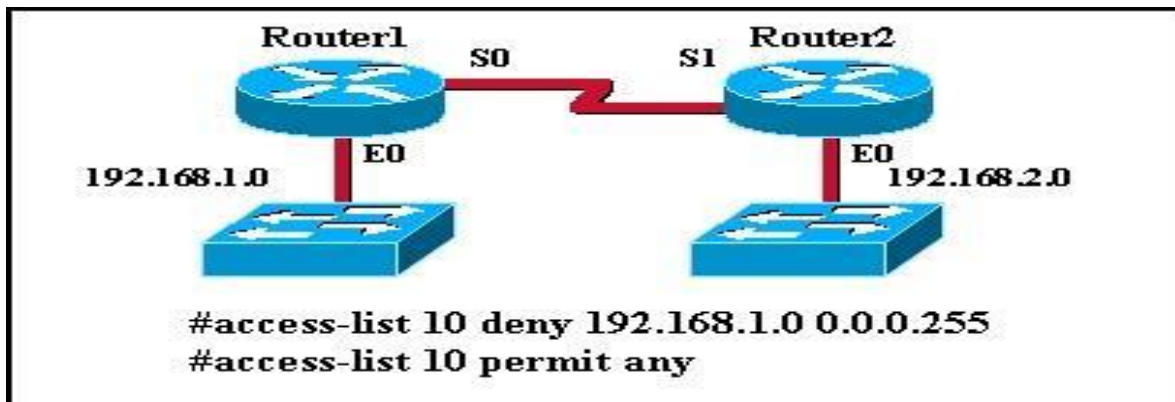
**Access-list 101 permit IP 20.20.20.0 0.0.0.255 host 200.200.200.200**

(Aquí se permite TODA la red **20.20.20.0** a la **200.200.200.200**)

Y no escribo más nada..... ¿PORQUE?

Porque una de las reglas de las **ACLs**, es que la última línea es un **DENY IMPLICITO**, o sea niega todo lo restante que no esté.

Un ejemplo gráfico:



Esas **ACLs** (sin importar en qué router se aplique) lo que nos indica que el tráfico de la RED 192.168.1.0 no está permitido, o sea el único tráfico será el de la RED 192.168.2.0 que si podrá llegar al otro lado.

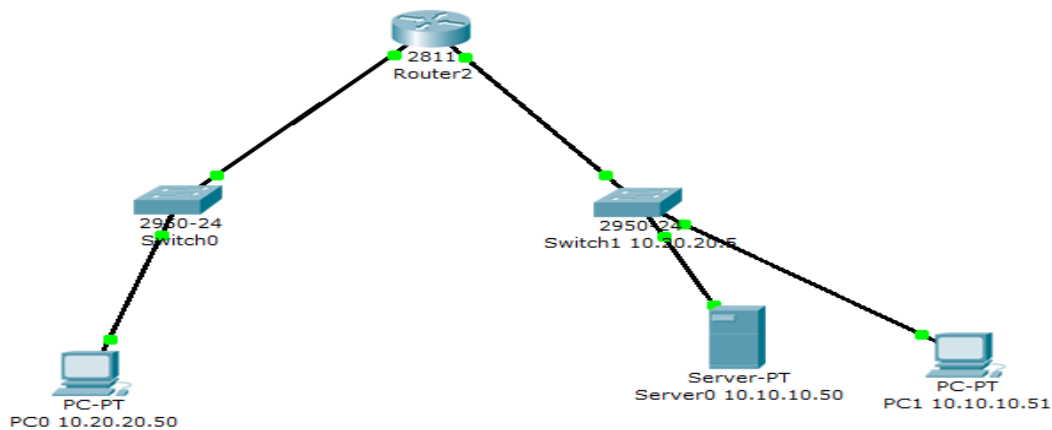
Pero tenemos un problema, es una posible incidencia de seguridad, ya que estamos negando algo de forma correcta, pero estamos permitiendo redes que quizás no conozcamos al configurar la **ACL** con el permit **ANY**.

## Ejercicio Número 2 Unidad 4



### EJERCICIO 1

Escribir un ACL que permita el tráfico de la PC0 a la PC1 y otro ACL que permita el tráfico de la PC0 al server.



### **A tener en cuenta:**

Un solo dispositivo se representa en una ACL con el identificador HOST o con la wildcard 0.0.0.0.

Ejemplos:

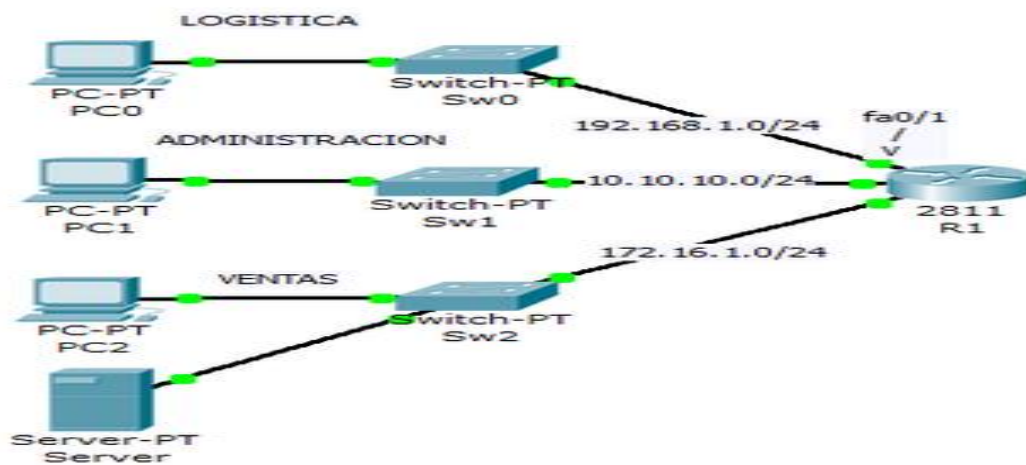
```
access-list 1 permit ip host 10.10.10.10 host 10.10.10.11
```

```
access-list 1 permit ip 10.10.10.10 0.0.0.0 10.10.10.11 0.0.0.0
```

Ambas cumplen el mismo objetivo, que es permitir el host 10.10.10.10 hacia el host 10.10.10.11, son maneras diferentes de configurarlas.

## EJERCICIO 2

Consigna: Logística y Ventas pueden verse entre sí, pero no pueden ver a Administración, sin embargo Administración puede ver a todas.



**RECORDAR:** en este caso, son redes /24, por ende, wildcard es 0.0.0.255

## TIPS EJERCICIO

Si te interesa el estudio de las ACL, les recomiendo estas lecturas:

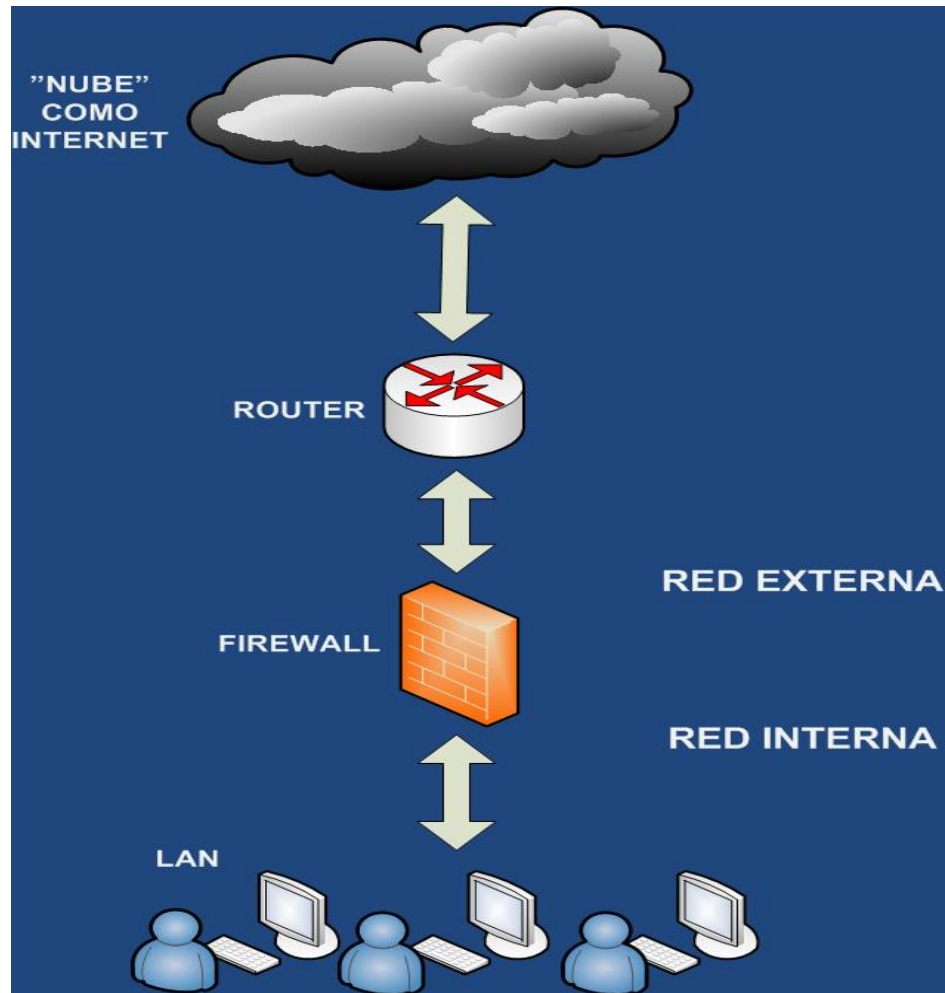
<https://www.cisco.com/c/en/us/support/docs/security/ios-firewall/23602-confaccesslists.html>

<https://www.oocities.org/hilmarz/cisco/acl.htm>

Tener en cuenta que estos links están referidos a equipamiento **CISCO**.

Si te interesa el estudio de las configuraciones de los routers & switches **CISCO**, les recomiendo que se bajen el **PACKET TRACER** como para arrancar, sino pueden bajarse el **GNS3** (<http://www.gns3.net/download/>) que es un emulador real de **IOS** de Cisco (requiere mucha memoria **RAM**).

**El donde proteger**, se implementará en un área que sea activo el firewall, o sea teniendo en cuenta los servicios o dispositivos a proteger, la ubicación del mismo será a mayor importancia para que afecte lo que necesitamos proteger.



**Ejemplo de donde ponerlo teniendo en cuenta la protección hacia dentro desde Internet, separando la red interna de la externa**

# Estructuración de una red segura

Cuando estamos al frente de una red, lo primero que se debería hacer es un relevamiento de todos los dispositivos involucrados y luego podremos tener una idea de si hay que modificar la topología o dejarla como esta.

Sabiendo que disponemos de equipos relacionados con la protección de datos, los mismos tendrían que estar posicionados en un sector que el acceso a esos datos cumplan con el propósito que necesitamos.

¿Sirve poner un firewall detrás de una red, lo dejamos configurado por defecto, o peor aún, a un servidor importante tiene acceso libre desde Internet de cualquier intruso?

De eso se trata la estructuración, de proteger los activos, la información confidencial, etc., de una manera eficiente y segura, teniendo en cuenta el posicionamiento de los dispositivos de seguridad o de los sistemas que tengamos para la protección.

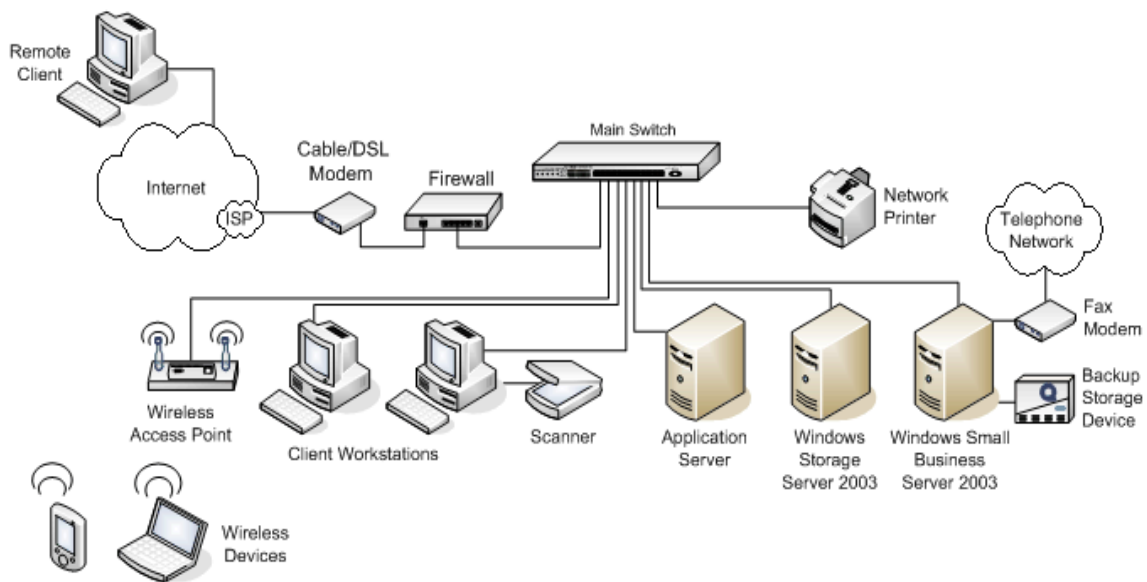
- Relevamiento de la red
- ¿Que proteger? ¿Qué activos?
- ¿En qué sector de la red están los mismos? ¿Podrían estar en otro lado?
- ¿Que dispongo para protegerlos?
- ¿Dónde los protejo o sea donde instaló el sistema de seguridad?
- ¿Está bien como lo deje? ¿Hay otras opciones? ¿En caso de que haya un acceso indebido, tengo una posibilidad de contingencia?

A veces puede resultar que uno se confunda por no saber cuál es la correcta ubicación de un dispositivo de seguridad o servicio, hay cientos de escenarios posibles, no hay un estándar para poder ubicarlos, entonces queda realizar estos puntos, comprenderlos y llevarlos a la práctica, de acuerdo al escenario que uno se encuentre.

### Ejercicio Número 3 Unidad 4



De acuerdo a la metodología enseñada, poner en práctica los 6 puntos en este dibujo de red, Exponer en el foro.



### **Recomendaciones y TIPS:**

- 1- Realizar un relevamiento
- 2- Determinar (improvisando) qué dispositivos se consideran proteger
- 3- Chequear si se encuentran bien posicionados dentro de la topología
- 4- Aplicar más medidas de seguridad si hicieran falta
- 5- ¿En caso de que se caiga la red, tengo alguna medida de backup?

# Armado de una red segura

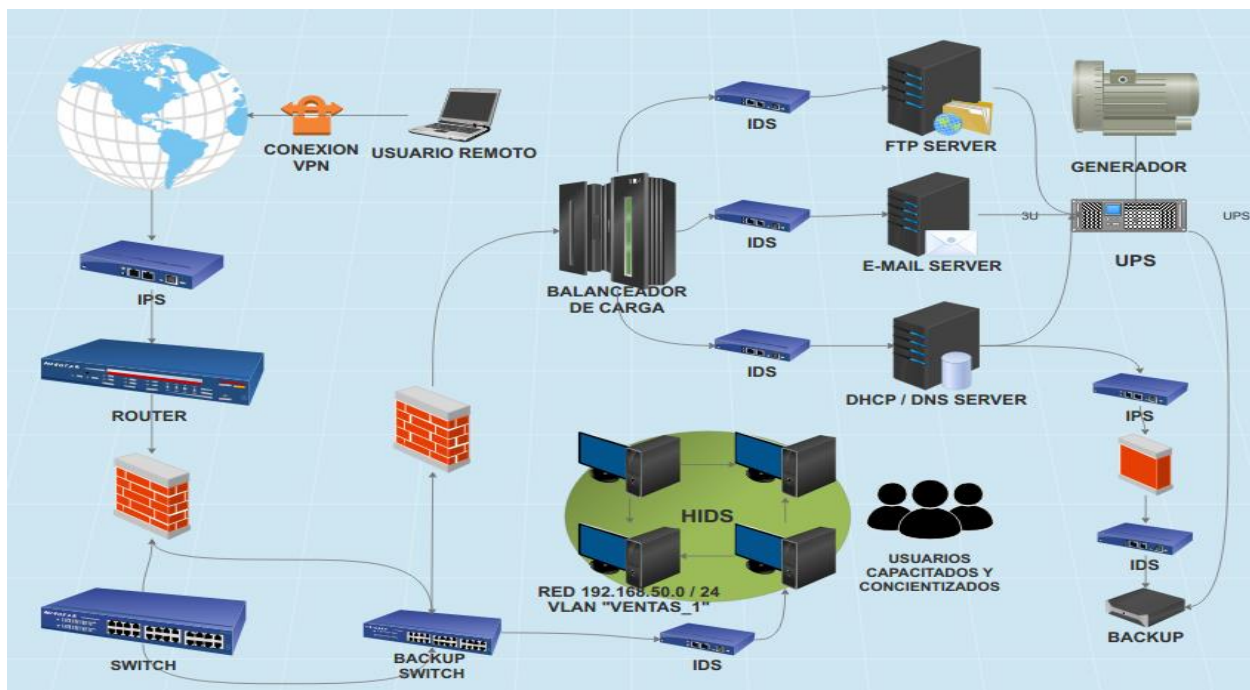
A lo largo de todo lo aprendido hasta ahora, hemos mencionado Dispositivos de seguridad (Firewall), servicios (DMZ, NAT, ACL, etc.).

¿La pregunta del millón es: cómo armar una red segura?

Implementando una metodología de protección y buen uso de todo lo relacionado llamado “seguridad”.

Chequear todos los dispositivos, usar métodos de actualización de software, antivirus, control de acceso físicos, cámaras, etc.

¿Cómo llevarlo a la práctica? Lo realizarán ustedes a través del final que se encuentra a continuación, luego de algunos TIPS a tener en cuenta.



Uno podría considerar que mirando esta topología tiene muy buena seguridad, pero si lo miramos más detalladamente, se verán procesos que se reiteran, que se encuentran mal aplicados y utilizados, tener 10 FW no es la solución, al contrario se suman más puntos de fallas en un relevamiento de seguridad.

## Dispositivos de Seguridad



### Tipos de Firewall existentes a tener en cuenta

**Filtrado de Paquetes**

**Proxy-Gateways de Aplicaciones**

**Dual-Homed Host**

**Screened Host**

**Screened Subnet**

**Inspección de Paquetes**

**Firewalls Personales**

### Sistemas de detección de intrusos ( IDS )

Disponemos de:

- N-IDS : garantiza la seguridad dentro de una red
- H-IDS : garantiza la seguridad en un host



### **Network IDS (N-IDS )**

Nos ofrece una forma de sistema que puede verificar paquetes de información que viajan por una o más líneas de la red para descubrir si se ha producido alguna actividad maliciosa o anormal

•**Hardware exclusivo**

•**Adaptadores de red en modo promiscuo**

•**Invisible**

•**No tienen IP**

•**Usualmente dos adaptadores**

•**Interno / Externo**

### **Host IDS (H-IDS)**

- **Analizan la información particular almacenada en registros**
- **Capturan paquetes de la red que se introducen/salen del host para poder verificar las señales de intrusión**
- **Chequea: Registros del sistema / Mensajes / Lastlogs / Wtmp**

**Puede detectar:**

- **Ataques por denegación de servicio**
  - **Puertas traseras**
  - **Trojanos**
- **Ejecución de códigos malignos**
- **Ataques de desbordamiento de búfer**
- **Intentos de acceso no autorizado**

## Ejercicio Final Módulo 1

### Respuestas a preguntas frecuentes, dudas y/o Consultas sobre el final

- El mismo se encuentra activo en una sección aparte de las unidades con el nombre de recurso.
- Los finales tienen que ser entregados en formato .DOC sin excepciones
- No tienen que superar los 10MB de tamaño de archivo
- Una vez lo terminan, lo suben a la sección llamada TAREA Examen Módulo 1: Trabajo Práctico Ejercicio Final.

Evaluación del módulo 1

|                                                                                     |                                                            |
|-------------------------------------------------------------------------------------|------------------------------------------------------------|
|  | Recurso<br>Trabajo Práctico - Final Número 1               |
|  | Tarea<br>Examen Módulo 1: Trabajo Práctico Ejercicio Final |
|  | Foro<br>Foro: Nos interesa tu opinión                      |

- En este caso, la fecha de entrega y finalización estará expuesta en este foro
- Las correcciones se harán de acuerdo a respetar la fecha de entrega, cuanto más se tarde en subir, más se tardará en evaluarlo, dado que hay que priorizar a los alumnos/as que entregan en fecha.
- **IMPORTANTE:** está prohibido hablar o postear sobre el final, las únicas consultas sobre el mismo deberán ser al instructor, los finales son personales (respetemos a los que quieren hacerlo sin ningún spoiler o ayuda).
- **Hay a disposición un foro donde nos interesa tu opinión general, respecto a todo el módulo, eso nos hará mejorar año a año.**

## **Cómo presentar los ejercicios de la unidad**

Hay dos tipos de ejercicios, los de la unidad (QUE NO SON OBLIGATORIOS) y los que se exponen como obligatorios (que son los finales de cada módulo)

La idea está en que cada uno pueda desarrollar todos los ejercicios y expresarlos en un archivo .doc o .pdf y lo suba al correspondiente foro que estará habilitado.

En el mismo, el formato del archivo será apellido\_UnidadX.doc (donde apellido será el de cada uno y la “X” el número de la unidad de los ejercicios)

Esto significa que en un solo archivo deberían estar todos los ejercicios de la unidad correspondiente, así centralizamos lo de cada uno.

Es muy IMPORTANTE que realicen todos los ejercicios (aun no siendo obligatorios) ya que, al ser un curso a distancia, es una herramienta para saber si hubo una buena comprensión de la unidad.

Luego los mismos serán revisados por el instructor, por eso es importante que lo hagan pronto, para que no se les sume ejercicios de otras unidades.

Pueden ser revisados por todos los demás alumnos e instructor para dar puntos de vista, ayuda o guía.

### **Los ejercicios de esta unidad no llevan calificación**

Los únicos ejercicios que tienen puntuación son los finales, que se realizan cada 4 unidades, pero más adelante se hablará de esto.



## **Bibliografía utilizada y sugerida**

Harrington, J.(2006) Manual práctico de seguridad de redes. Editorial Anaya Multimedia. México

Hush J.(2020) Redes Informáticas Para Principiantes: La Guía Completa de la Tecnología Inalámbrica, La Seguridad de Redes, Arquitectura de Las Computadoras Y Los Sistemas de Comunicación. Editorial Charlie Creative Lab. España

Dorsel, R.(2020) Hacking for Beginners: Mastery Guide to Learn and Practice the Basics of Computer and Cyber Security. Editorial Charlie Creative Lab. EEUU

Trew, P.(2020) Kali Linux Hacking: A Complete Guide to Learn the Fundamentals of Hacking, Cyber Security, and Penetration Testing. Editorial Charlie Creative Lab. EEUU

Knox, J.(2020) Computer Hacking. Editorial Charlie Creative Lab. EEUU